INVESTIGACIÓN DE INCIDENTES DE SEGURIDAD

# Informe técnico de análisis de logs del SIEM

Cliente: Cliente ejemplo

Analista: Braian Fernandez

Fecha del informe: 29/10/2026

Fuente: SOC_L2_Logs_Ampliados_Multiples_Incidentes.xlsx · 715 eventos · 2026-10-23 07:46:07 a 2026-10-23 13:44:06

| 715 | 6 | 25 | 10 | 10 | 37 |
|---|---|---|---|---|---|
| Eventos | Incidentes | Hallazgos | Críticos | Altos | IoC |

Este informe fue generado por la aplicación SOC Incident Analyzer. Los hallazgos y su criticidad se determinan con reglas aplicadas directamente sobre los registros y cada conclusión cita los Log_ID que la sustentan. La explicación técnica y el plan de acción fueron redactados con asistencia de IA (claude-sonnet-5-5) y verificados contra el Excel: se descartan las citas o direcciones que no existan en los datos.

# 1. Resumen ejecutivo

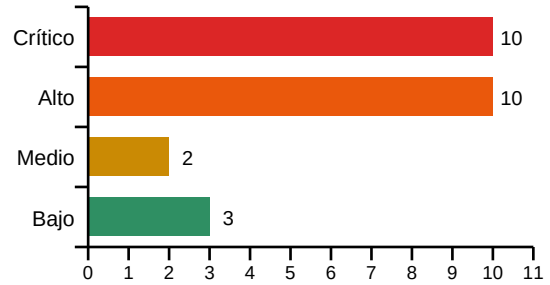
El export del 23-oct-2026 (07:46–13:44) contiene seis incidentes: cuatro Críticos (INC-002, INC-003, INC-004, INC-006) y dos Altos (INC-001, INC-005). Afectan a DC-01, WS-031, APP-SRV01, FS-SRV01, WS-023, WS-018 y WEB-01. Los datos no permiten unirlos; las hipótesis de relación tienen confianza baja.

Hechos más graves: en INC-002, CORP\admin inició sesión por RDP desde una IP externa (EVT-00188). Después se ejecutó PowerShell codificado (EVT-00198), se accedió a Finance (EVT-00227), se ejecutó un comando para comprimir C:\Temp\reports (EVT-00232) y el firewall permitió una conexión saliente a 203.0.113.88:443 (EVT-00235). En INC-003 se ejecutó vssadmin delete shadows /all /quiet (EVT-00314). En INC-004 el proxy registró 22 POST HTTPS permitidos, unos 253,3 MB, hacia 198.51.100.88 (EVT-00430 a EVT-00461). En INC-006 DefaultAppPool ejecutó cmd.exe /c whoami en WEB-01 (EVT-00599). Los logs no prueban la transferencia de datos ni el resultado del borrado.

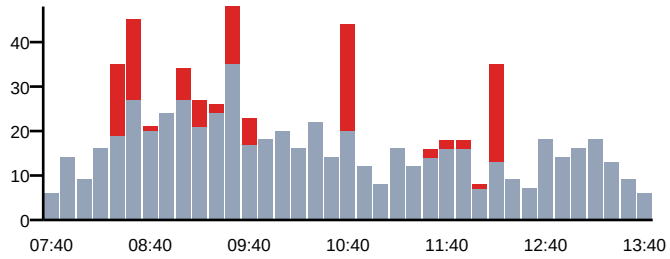
Prioridad inmediata: aislar los equipos implicados, restablecer credenciales y cerrar sesiones de admin, mgarcia, backupsvc, rrojas y helpdesk, y bloquear las IP externas observadas. Después hay que investigar si hubo fuga de datos y eliminar la persistencia de APP-SRV01.

| ID | Criticidad | Incidente | Ventana | Hosts | Hall. |
|---|---|---|---|---|---|
| **INC-001** | Alto | Password spraying desde 203.0.113.74 con inicio de sesión exitoso de CORP\mgarcia en DC-01 y asignación de privilegios especiales en WS-031 | 08:25–08:40 | DC-01, WS-031 | 3 |
| **INC-002** | Crítico | Compromiso de CORP\admin vía RDP externo, movimiento lateral a FS-SRV01, acceso a 'Finance' y posible exfiltración | 09:02–09:21 | APP-SRV01, FS-SRV01 | 9 |
| **INC-003** | Crítico | Recolección masiva en Finance y eliminación de copias de sombra con la cuenta backupsvc (WS-023 / FS-SRV01) | 09:36–09:43 | WS-023, FS-SRV01 | 3 |
| **INC-004** | Crítico | Posible exfiltración por HTTPS de ~253,3 MB desde WS-018 (CORP\rrojas) hacia 198.51.100.88 tras acceso a recurso Legal y compresión de datos | 10:40–10:49 | FS-SRV01, WS-018 | 3 |
| **INC-005** | Alto | Persistencia en APP-SRV01 mediante tarea programada y servicio creados por CORP\helpdesk | 11:37–12:04 | APP-SRV01 | 1 |
| **INC-006** | Crítico | Ataque web contra WEB-01 desde 192.0.2.91 con posible ejecución remota de comandos (cmd.exe lanzado por DefaultAppPool) | 12:10–12:15 | WEB-01 | 2 |

**Hallazgos por criticidad**




**Eventos por ventana de 10 min (actividad marcada vs resto)**




# 2. Alcance y metodología

Se analizó el export del SIEM «SOC_L2_Logs_Ampliados_Multiples_Incidentes.xlsx» (715 eventos, 11 hosts, 12 cuentas, 2026-10-23 07:46:07 a 2026-10-23 13:44:06, 5 h 57 min). El análisis combina tres pasos:

- Detección determinista: reglas explícitas sobre los campos del Excel (fuerza bruta, inicios de sesión sospechosos, escalamiento, comandos y procesos, movimiento lateral, exfiltración, persistencia, ataques web y anomalías de calidad de datos). Cada hallazgo conserva sus Log_ID.
- Correlación: los hallazgos se agrupan en incidentes si comparten un actor (IP externa o cuenta). Compartir solo un host o un recurso NO fusiona incidentes; esos casos se reportan como hipótesis de baja confianza.
- Redacción asistida por IA: explicación técnica, impacto y plan de acción redactados a partir de la evidencia; la criticidad la fija el motor y un validador descarta Log_ID o IP inexistentes.

| Regla | Descripción | Hallazgos |
|---|---|---|
| **brute_force** | Fuerza bruta / password spraying: ráfagas de 4625 desde una misma IP | 2 |

| Regla | Descripción | Hallazgos |
|---|---|---|
| **external_logon** | Inicio de sesión exitoso (4624) desde IP externa | 2 |
| **privilege** | Privilegios especiales (4672) asociados a origen externo o cuenta comprometida | 2 |
| **persistence** | Persistencia: tareas programadas (4698) y servicios nuevos (7045) | 1 |
| **cmd** | Comandos/procesos sospechosos (PowerShell codificado, reconocimiento, compresión, vssadmin, shell del servicio web…) | 7 |
| **lateral** | Movimiento lateral: autenticación en un host con origen en otro host (source=…) | 1 |
| **mass_access** | Acceso masivo/secuencial a archivos (4663) | 1 |
| **sensitive_share** | Acceso a recursos compartidos sensibles (5140/5145) | 2 |
| **exfil_proxy** | Exfiltración: ráfaga de POST al proxy hacia IP externa | 1 |
| **outbound_shell** | Conexión saliente a IP externa iniciada por shell/proceso inusual | 1 |
| **web_attack** | Ataque web: ráfagas HTTP con patrones de webshell/enumeración | 1 |
| **dataquality** | Calidad de datos: hosts con distintas grafías, fuente de log incoherente, cuentas similares | 3 |
| **siem_underclass** | Brecha del SIEM: evidencias de incidentes clasificadas como Informational | 1 |

# 3. ¿Uno o varios incidentes?

Los datos describen seis incidentes distintos, no una única campaña demostrada. El motor no encontró eventos que enlacen directamente cuentas, hosts o IP de origen entre incidentes. Las tres hipótesis entregadas tienen confianza Baja. H-01: INC-002 e INC-003 tocan el recurso 'finance', pero con cuentas, IP de origen y hosts distintos. H-02 y H-03: IP externas del mismo /24 (203.0.113.74 y 203.0.113.88; 198.51.100.77 y 198.51.100.88), lo que no prueba infraestructura común y puede ser casualidad. Por eso no se unen los incidentes. Algunos incidentes sí tienen coherencia interna. INC-002 encadena fuerza bruta RDP, inicio de sesión, PowerShell codificado, movimiento lateral, acceso a Finance, compresión y conexión saliente. INC-004 encadena acceso a Legal, compresión y 22 POST HTTPS salientes. Los dos incidentes de exfiltración posible (INC-002 e INC-004) usan hosts, cuentas y destinos distintos. Los logs no confirman transferencia de datos en ninguno de los dos. Tampoco hay evidencia en los logs sobre cómo se obtuvieron o se usaron las cuentas internas backupsvc, rrojas y helpdesk, ni de si sus titulares actuaron de forma autorizada. En INC-001 backupsvc y helpdesk figuran entre las cuentas con intentos fallidos. Es un dato que conviene verificar, pero no hay evidencia en los logs de un inicio de sesión exitoso de esas cuentas ni de un vínculo con INC-003 o INC-005. Limitaciones: no hay zona horaria, ni línea base histórica, ni inteligencia de amenazas, y el campo Destination está vacío en el 36,6 % de los eventos.

| ID | Hipótesis (no confirmada) | Confianza |
|---|---|---|
| **H-01** | Los incidentes INC-002, INC-003 tocan el mismo recurso sensible 'finance' (INC-002: 09:02-09:21; INC-003: 09:36-09:43), pero con cuentas, IP de origen y hosts distintos. Coincidencia de recurso objetivo. Ningún evento enlaza directamente las cuentas o los hosts de ambos incidentes. | Baja |
| **H-02** | Las IP externas 203.0.113.74, 203.0.113.88 comparten el segmento 203.0.113.0/24 y aparecen en incidentes distintos (INC-001, INC-002). Coincidencia de red /24. No prueba una infraestructura común; puede ser casualidad o un artefacto del rango usado. | Baja |
| **H-03** | Las IP externas 198.51.100.77, 198.51.100.88 comparten el segmento 198.51.100.0/24 y aparecen en incidentes distintos (INC-002, INC-004). Coincidencia de red /24. No prueba una infraestructura común; puede ser casualidad o un artefacto del rango usado. | Baja |

# 4. Incidentes y hallazgos

## INC-001 Password spraying desde 203.0.113.74 con inicio de sesión exitoso de CORP\mgarcia en DC-01 y asignación de privilegios especiales en WS-031

ALTO

2026-10-23 08:25:00 a 08:40:00 · Hosts: DC-01, WS-031 · IP externas: 203.0.113.74 · Cuentas: mgarcia

Entre las 08:25:00 y las 08:35:08 se registraron 33 fallos de autenticación (4625) en DC-01 desde la IP externa 203.0.113.74. Los fallos afectaron a 8 cuentas (jlopez, aperez, helpdesk, mgarcia, rrojas, slopez, backupsvc, dtorres), con 4 o 5 intentos por cuenta y una mediana de 19 s entre intentos. Este patrón es consistente con password spraying (T1110.003). A las 08:39:00 CORP\mgarcia inició sesión correctamente en DC-01 desde la misma IP (EVT-00123, 4624). A las 08:40:00 se registró el evento 4672 (privilegios especiales asignados) para mgarcia en WS-031, con origen 203.0.113.74 (EVT-00126). La secuencia sugiere que las credenciales de mgarcia se obtuvieron por adivinación y se usaron después. No hay evidencia en los logs de actividad posterior a las 08:40:00, de movimiento lateral ni de exfiltración. Los logs tampoco permiten determinar el tipo de inicio de sesión.

**Confianza de la agrupación:** Alta. La secuencia es coherente y está respaldada por logs: 33 fallos desde una sola IP externa contra 8 cuentas, un inicio de sesión exitoso de una de las cuentas atacadas desde esa IP, y un evento 4672 posterior. Las limitaciones son que no hay línea base, no hay actividad posterior a las 08:40:00 en la evidencia, y la IP no tiene reputación ni geolocalización. La hipótesis H-02 sobre INC-002 tiene confianza Baja (coincidencia de /24) y no se une a este incidente.

### CRONOLOGÍA

| Hora | Paso | Evidencia |
|---|---|---|
| 08:25:00 | Inicio de la ráfaga de fallos de autenticación (4625) desde 203.0.113.74 contra DC-01, empezando por jlopez, con rotación entre cuentas. | EVT-00057, EVT-00058, EVT-00060, EVT-00061 |
| 08:25:57 | Primer fallo contra CORP\mgarcia; se registran 4 fallos para esta cuenta (08:25:57, 08:28:29, 08:31:01 y 08:33:33). | EVT-00061, EVT-00074, EVT-00086, EVT-00104 |
| 08:35:08 | Último fallo de la ráfaga (33 fallos, 8 cuentas, 608 s). | EVT-00111 |
| 08:39:00 | Inicio de sesión exitoso (4624) de CORP\mgarcia en DC-01 desde 203.0.113.74, 3 min 52 s después del último fallo. | EVT-00123 |
| 08:40:00 | Asignación de privilegios especiales (4672) a CORP\mgarcia en WS-031 con origen 203.0.113.74. | EVT-00126 |

## F-001 Password spraying desde 203.0.113.74

ALTO

Fuerza bruta · Acceso a credenciales · MITRE ATT&CK (orientativo): T1110.003 · 08:25:00–08:35:08 · 33 eventos

### CRITICIDAD Y JUSTIFICACIÓN

Severidad Alto, según el motor: 33 fallos en 10 min 8 s desde una IP externa, contra 8 cuentas, y con un inicio de sesión exitoso posterior desde la misma IP (EVT-00123).

### EXPLICACIÓN TÉCNICA

Se registraron 33 eventos 4625 (bad password) en DC-01 desde 203.0.113.74, entre 08:25:00 (EVT-00057) y 08:35:08 (EVT-00111). Afectaron a 8 cuentas distintas, con 4 o 5 intentos por cuenta (jlopez 5; aperez, helpdesk, mgarcia, rrojas, slopez, backupsvc y dtorres 4 cada una). Los intentos van rotando entre cuentas, con una mediana de 19 s. Es consistente con password spraying (T1110.003). Entre las cuentas objetivo hay una de servicio (backupsvc) y una de soporte (helpdesk).

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00057** | 08:25:00 | DC-01 | jlopez | 203.0.113.74 | 4625 · An account failed to log on - bad password | Warning |
| **EVT-00058** | 08:25:19 | DC-01 | aperez | 203.0.113.74 | 4625 · An account failed to log on - bad password | Warning |
| **EVT-00060** | 08:25:38 | DC-01 | helpdesk | 203.0.113.74 | 4625 · An account failed to log on - bad password | Warning |
| **EVT-00061** | 08:25:57 | DC-01 | mgarcia | 203.0.113.74 | 4625 · An account failed to log on - bad password | Warning |
| **EVT-00063** | 08:26:16 | DC-01 | rrojas | 203.0.113.74 | 4625 · An account failed to log on - bad password | Warning |
| **EVT-00065** | 08:26:35 | DC-01 | slopez | 203.0.113.74 | 4625 · An account failed to log on - bad password | Warning |
| **EVT-00066** | 08:26:54 | DC-01 | backupsvc | 203.0.113.74 | 4625 · An account failed to log on - bad password | Warning |
| **EVT-00068** | 08:27:13 | DC-01 | dtorres | 203.0.113.74 | 4625 · An account failed to log on - bad password | Warning |
| **EVT-00069** | 08:27:32 | DC-01 | jlopez | 203.0.113.74 | 4625 · An account failed to log on - bad password | Warning |
| **EVT-00110** | 08:34:49 | DC-01 | dtorres | 203.0.113.74 | 4625 · An account failed to log on - bad password | Warning |
| **EVT-00111** | 08:35:08 | DC-01 | jlopez | 203.0.113.74 | 4625 · An account failed to log on - bad password | Warning |

Se muestran 11 de 33 eventos (primeros 9 y últimos 2). Rango completo: EVT-00057 a EVT-00111. IDs completos: EVT-00057, EVT-00058, EVT-00060, EVT-00061, EVT-00063, EVT-00065, EVT-00066, EVT-00068, EVT-00069, EVT-00071, EVT-00073, EVT-00074, EVT-00075, EVT-00077, EVT-00078, EVT-00079, EVT-00081, EVT-00084, EVT-00085, EVT-00086, EVT-00088, EVT-00092, EVT-00094, EVT-00096, EVT-00099, EVT-00100, EVT-00101, EVT-00104, EVT-00105, EVT-00107, EVT-00108, EVT-00110, EVT-00111

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Posible compromiso de credenciales de cualquiera de las 8 cuentas objetivo. De ellas, solo hay evidencia de éxito para mgarcia. Para el resto, no hay evidencia en los logs de acceso exitoso.

### PLAN DE ACCIÓN

**Investigar**
- Revisar en DC-01 y otros sistemas si hubo 4624 desde 203.0.113.74 para cuentas distintas de mgarcia, dentro y fuera de la ventana analizada.
- Comprobar si las 8 cuentas atacadas tienen otros intentos desde otras IP.
- Identificar el servicio expuesto (VPN, RDP, Kerberos/NTLM) por el que llegó el tráfico a DC-01, ya que los logs no lo indican.
- Revisar el bloqueo de cuentas y la política de umbral configurada.

**Contener**
- Bloquear 203.0.113.74 en el perímetro.
- Forzar el restablecimiento de contraseña de las 8 cuentas objetivo, con prioridad en backupsvc y helpdesk.

**Remediar**
- Habilitar MFA en accesos externos.
- Ajustar la política de bloqueo de cuentas y las alertas por fallos distribuidos entre varias cuentas.
- Restringir la exposición de DC-01 a orígenes externos.
- Auditar la robustez de las contraseñas de las cuentas de servicio.

## ALTO F-002 Inicio de sesión exitoso de mgarcia desde IP externa 203.0.113.74

Inicios sospechosos · Acceso inicial · MITRE ATT&CK (orientativo): T1078 · 08:39:00–08:39:00 · 1 evento

### CRITICIDAD Y JUSTIFICACIÓN

Severidad Alto, según el motor: es un inicio de sesión exitoso desde una IP externa, 3 min 52 s después de la ráfaga de fallos desde la misma IP, y el destino es un controlador de dominio.

### EXPLICACIÓN TÉCNICA

A las 08:39:00, CORP\mgarcia inició sesión correctamente (4624) en DC-01 desde 203.0.113.74 (EVT-00123). Esa misma IP generó antes 4 fallos contra mgarcia (EVT-00061, EVT-00074, EVT-00086, EVT-00104) y 33 fallos en total. La secuencia sugiere que la cuenta se usó como cuenta válida (T1078) tras adivinar la contraseña. Los logs no indican el tipo de inicio de sesión; el motor marca rdp=false.

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00123** | 08:39:00 | DC-01 | mgarcia | 203.0.113.74 | 4624 · An account was successfully logged on | Informational |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Acceso no autorizado probable a un controlador de dominio con una cuenta de dominio. Esto expone el directorio y puede permitir actividad posterior. Los logs entregados no muestran lo que hizo la sesión en DC-01.

### PLAN DE ACCIÓN

**Investigar**
- Revisar toda la actividad de CORP\mgarcia en DC-01 desde las 08:39:00 (procesos, cambios de directorio, otros inicios de sesión).
- Determinar el tipo de inicio de sesión y la duración de la sesión.
- Confirmar con el usuario si reconoce el acceso.

**Contener**
- Deshabilitar o restablecer la contraseña de CORP\mgarcia y cerrar sus sesiones activas.
- Revocar tokens y tickets Kerberos de la cuenta.

**Remediar**
- Aplicar MFA y restringir el acceso de cuentas de usuario a controladores de dominio.
- Revisar la necesidad de que mgarcia tenga acceso a DC-01.

ALTO

### F-003 Asignación de privilegios especiales a mgarcia desde 203.0.113.74

Escalamiento · Escalamiento de privilegios · MITRE ATT&CK (orientativo): T1078, T1134 · 08:40:00–08:40:00 · 1 evento

#### CRITICIDAD Y JUSTIFICACIÓN

Severidad Alto, según el motor: se asignaron privilegios especiales a una cuenta ya comprometida (EVT-00123), con origen en la misma IP externa, y en un segundo host (WS-031).

#### EXPLICACIÓN TÉCNICA

A las 08:40:00 se registró un evento 4672 (privilegios especiales asignados a un nuevo inicio de sesión) para CORP\mgarcia en WS-031, con Source_IP 203.0.113.74 (EVT-00126). Ocurre 1 minuto después del inicio de sesión exitoso en DC-01 (EVT-00123). El evento indica que la sesión recibió privilegios sensibles. Combinado con el origen externo, sugiere uso de la cuenta con privilegios elevados desde la IP del atacante (T1078, T1134). Los logs no detallan qué privilegios se asignaron. No hay evidencia en los logs de un 4624 en WS-031 dentro de la evidencia de este hallazgo.

#### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00126** | 08:40:00 | WS-031 | mgarcia | 203.0.113.74 | 4672 · Special privileges assigned to new logon | Informational |

#### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Posible ampliación del acceso del atacante a WS-031 con privilegios sensibles, lo que podría facilitar movimiento lateral o acceso a credenciales. Los logs no muestran el uso de esos privilegios.

#### PLAN DE ACCIÓN

**Investigar**

- Revisar en WS-031 los eventos 4624 y 4672 asociados a mgarcia y la actividad de procesos posterior a las 08:40:00.
- Determinar cómo accedió mgarcia a WS-031 desde 203.0.113.74 y el tipo de inicio de sesión.
- Verificar a qué grupos pertenece mgarcia y por qué dispone de privilegios especiales.
- Buscar otros hosts con actividad de mgarcia o de 203.0.113.74.

**Contener**

- Aislar WS-031 de la red si la revisión confirma actividad no autorizada.
- Deshabilitar la cuenta mgarcia y cerrar todas sus sesiones.

**Remediar**

- Aplicar mínimo privilegio a mgarcia y revisar su pertenencia a grupos privilegiados.
- Si se confirma el compromiso, restablecer las credenciales de la cuenta y revisar el host WS-031 antes de reincorporarlo.

CRÍTICO

### INC-002 Compromiso de CORP\admin vía RDP externo, movimiento lateral a FS-SRV01, acceso a 'Finance' y posible exfiltración

2026-10-23 09:02:00 a 09:21:00 · Hosts: APP-SRV01, FS-SRV01 · IP externas: 198.51.100.77, 203.0.113.88 · Cuentas: admin

Entre las 09:02:00 y las 09:21:00 la cuenta CORP\admin fue objeto de 4 fallos de autenticación RDP en APP-SRV01 desde la IP externa 198.51.100.77 (EVT-00174, EVT-00175, EVT-00178, EVT-00180), seguidos de un inicio de sesión exitoso desde esa misma IP a las 09:06:00 (EVT-00188) y asignación de privilegios especiales (EVT-00193). Después se ejecutó PowerShell con -EncodedCommand (EVT-00198) y comandos de reconocimiento (EVT-00207, EVT-00214). Desde APP-SRV01 (10.10.2.15) hubo un fallo y luego un éxito de red contra FS-SRV01 (EVT-00222, EVT-00225), y se registró acceso al recurso Finance y a Finance\Budget2027.xlsx (EVT-00227, EVT-00231). A las 09:20:00 se ejecutó un comando tar.exe para comprimir C:\Temp\reports en C:\Temp\finance.zip (EVT-00232) y a las 09:21:00 el firewall permitió una conexión saliente de powershell.exe a 203.0.113.88:443 (EVT-00235). La secuencia es consistente con compromiso y posible exfiltración; los logs no prueban la transferencia de datos.

**Confianza de la agrupación:** Alta. La secuencia es coherente y continua en el tiempo, con la misma cuenta, la misma IP de origen y los mismos hosts, y cada paso tiene un Log_ID. Dos limitaciones: no hay evidencia en los logs del contenido del comando codificado, de que finance.zip se creara ni de que se transfirieran datos. Tampoco hay reputación de IP ni línea base.

### CRONOLOGÍA

| Hora | Paso | Evidencia |
|---|---|---|
| 09:02:00 | Inicio de ráfaga de fallos RDP (4625, LogonType=10) contra CORP\admin en APP-SRV01 desde 198.51.100.77 (4 fallos hasta 09:05:00) | EVT-00174, EVT-00175, EVT-00178, EVT-00180 |
| 09:06:00 | Inicio de sesión RDP exitoso de CORP\admin en APP-SRV01 desde la IP externa 198.51.100.77 | EVT-00188 |
| 09:07:00 | Asignación de privilegios especiales (4672) a la sesión de CORP\admin | EVT-00193 |
| 09:09:00 | Ejecución de PowerShell con -EncodedCommand (proceso padre cmd.exe) | EVT-00198 |
| 09:11:00 | Script block de PowerShell con Get-LocalGroupMember Administrators y Get-SmbShare; a las 09:13:00 se ejecutó net.exe view \\FS-SRV01 | EVT-00207, EVT-00214 |
| 09:15:00 | Fallo y luego éxito (09:16:00) de autenticación de red (LogonType=3) de CORP\admin en FS-SRV01 desde APP-SRV01 (10.10.2.15) | EVT-00222, EVT-00225 |
| 09:17:00 | Acceso al recurso compartido \\FS-SRV01\Finance y al archivo Finance\Budget2027.xlsx (09:18:00) | EVT-00227, EVT-00231 |
| 09:20:00 | Se ejecutó tar.exe para comprimir C:\Temp\reports en C:\Temp\finance.zip en APP-SRV01 | EVT-00232 |
| 09:21:00 | Conexión saliente permitida de APP-SRV01 a 203.0.113.88:443 iniciada por powershell.exe | EVT-00235 |

ALTO

## F-004 Fuerza bruta por RDP desde 198.51.100.77

Fuerza bruta · Acceso a credenciales · MITRE ATT&CK (orientativo): T1110.001 · 09:02:00–09:05:00 · 4 eventos

### CRITICIDAD Y JUSTIFICACIÓN

Alto: 4 fallos en 3 min desde una IP externa y un inicio de sesión exitoso posterior desde la misma IP (EVT-00188).

### EXPLICACIÓN TÉCNICA

Se registraron 4 eventos 4625 (RDP, LogonType=10) contra CORP\admin en APP-SRV01 desde la IP externa 198.51.100.77, entre las 09:02:00 y las 09:05:00 (EVT-00174, EVT-00175, EVT-00178, EVT-00180). El intervalo es de 1 minuto entre intentos. Es consistente con fuerza bruta o adivinación de credenciales contra una sola cuenta (T1110.001).

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00174** | 09:02:00 | APP-SRV01 | admin | 198.51.100.77 | 4625 · An account failed to log on (LogonType=10; RDP) | Medium |
| **EVT-00175** | 09:03:00 | APP-SRV01 | admin | 198.51.100.77 | 4625 · An account failed to log on (LogonType=10; RDP) | Medium |
| **EVT-00178** | 09:04:00 | APP-SRV01 | admin | 198.51.100.77 | 4625 · An account failed to log on (LogonType=10; RDP) | Medium |
| **EVT-00180** | 09:05:00 | APP-SRV01 | admin | 198.51.100.77 | 4625 · An account failed to log on (LogonType=10; RDP) | Medium |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Posible obtención de credenciales válidas de una cuenta administrativa mediante RDP expuesto a Internet.

### PLAN DE ACCIÓN

**Investigar**

- Revisar si hubo otros intentos de RDP desde 198.51.100.77 u otras IP externas contra APP-SRV01 fuera de esta ventana.
- Determinar por qué el RDP de APP-SRV01 es accesible desde Internet y si existe bloqueo de cuenta o MFA.

**Contener**

- Bloquear 198.51.100.77 en el perímetro.
- Restringir el acceso RDP externo a APP-SRV01.

**Remediar**

- Restablecer la contraseña de CORP\admin.
- Exigir MFA y acceso RDP solo por VPN o bastión.
- Configurar umbrales de bloqueo de cuenta y alertas de fallos de autenticación.

## CRÍTICO F-005 Inicio de sesión exitoso de admin desde IP externa 198.51.100.77

Inicios sospechosos · Acceso inicial · MITRE ATT&CK (orientativo): T1078, T1021.001 · 09:06:00–09:06:00 · 1 evento

### CRITICIDAD Y JUSTIFICACIÓN

Crítico: acceso remoto por RDP desde IP externa, inmediatamente después de fallos, con una cuenta administrativa.

### EXPLICACIÓN TÉCNICA

A las 09:06:00 CORP\admin inició sesión con éxito (4624, LogonType=10, RDP) en APP-SRV01 desde 198.51.100.77 (EVT-00188), 1 minuto después de los 4 fallos desde la misma IP. Sugiere uso de credenciales válidas tras adivinación (T1078, T1021.001).

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00188** | 09:06:00 | APP-SRV01 | admin | 198.51.100.77 | 4624 · An account was successfully logged on (LogonType=10; RDP) | High |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Control interactivo de APP-SRV01 con privilegios administrativos por un origen externo.

### PLAN DE ACCIÓN

**Investigar**
- Revisar la sesión RDP iniciada en EVT-00188 (duración, cierre de sesión, actividad posterior).
- Confirmar con el titular de la cuenta que no reconoce este acceso.

**Contener**
- Cerrar las sesiones activas de CORP\admin.
- Deshabilitar o aislar la cuenta y aislar APP-SRV01 de la red.

**Remediar**
- Rotar las credenciales de CORP\admin y de cualquier cuenta que haya iniciado sesión en APP-SRV01.
- Revisar la política de cuentas administrativas y limitar su exposición remota.

## CRÍTICO F-006 Asignación de privilegios especiales a admin desde 198.51.100.77

Escalamiento · Escalamiento de privilegios · MITRE ATT&CK (orientativo): T1078, T1134 · 09:07:00–09:07:00 · 1 evento

### CRITICIDAD Y JUSTIFICACIÓN

Crítico: el evento ocurre en una sesión originada en una IP externa, de una cuenta ya vista como comprometida (EVT-00188) y administrativa.

### EXPLICACIÓN TÉCNICA

A las 09:07:00 se registró el evento 4672 (privilegios especiales asignados) para CORP\admin en APP-SRV01 con origen 198.51.100.77 (EVT-00193), un minuto después del acceso externo. Sugiere que la sesión externa tuvo privilegios elevados; el log no detalla qué privilegios.

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00193** | 09:07:00 | APP-SRV01 | admin | 198.51.100.77 | 4672 · Special privileges assigned to new logon | Medium |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Una sesión con privilegios sensibles permite volcado de credenciales, cambios de configuración y persistencia.

### PLAN DE ACCIÓN

**Investigar**
- Determinar qué privilegios se asignaron, porque no hay evidencia en los logs.
- Revisar en APP-SRV01 actividad sensible posterior a las 09:07:00, como acceso a LSASS o creación de cuentas.

**Contener**
- Aislar APP-SRV01 y revocar las sesiones de CORP\admin.

**Remediar**
- Aplicar el principio de mínimo privilegio y cuentas administrativas separadas.
- Considerar APP-SRV01 como comprometido hasta completar el análisis forense.

## CRÍTICO F-007 PowerShell con comando codificado en APP-SRV01 (admin)

Comandos y procesos · Ejecución · MITRE ATT&CK (orientativo): T1059.001, T1027 · 09:09:00–09:09:00 · 1 evento

### CRITICIDAD Y JUSTIFICACIÓN

Crítico: comando codificado ejecutado dentro de una sesión de origen externo, con proceso padre cmd.exe, tras el acceso con una cuenta administrativa.

### EXPLICACIÓN TÉCNICA

A las 09:09:00 CORP\admin ejecutó en APP-SRV01 'powershell.exe -NoProfile -EncodedCommand [REDACTED_SYNTHETIC]' con proceso padre cmd.exe (EVT-00198), y el origen asociado es 198.51.100.77. El contenido codificado no está disponible (no hay evidencia en los logs). El uso de -EncodedCommand es consistente con ocultación del script (T1059.001, T1027).

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00198** | 09:09:00 | APP-SRV01 | admin | 198.51.100.77 | 4688 · powershell.exe -NoProfile -EncodedCommand [REDACTED_SYNTHETIC] | High |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Ejecución de código no visible para el cliente en un servidor, que podría servir para descarga de herramientas, persistencia o evasión.

### PLAN DE ACCIÓN

**Investigar**
- Obtener y decodificar el comando completo de EVT-00198 desde los logs originales o el 4104.
- Buscar procesos hijo, conexiones de red y archivos creados por ese PowerShell.

**Contener**
- Aislar APP-SRV01 y terminar los procesos PowerShell sospechosos.

**Remediar**
- Habilitar Script Block Logging y registro de línea de comandos en todos los servidores.
- Aplicar restricciones como Constrained Language Mode o AppLocker a PowerShell.

## ALTO F-008 Comandos de reconocimiento en APP-SRV01 (admin)

Comandos y procesos · Descubrimiento · MITRE ATT&CK (orientativo): T1087, T1069, T1135 · 09:11:00–09:13:00 · 2 eventos

### CRITICIDAD Y JUSTIFICACIÓN

Alto: reconocimiento posterior al acceso, ejecutado desde una sesión de origen externo, que precede al movimiento hacia FS-SRV01.

### EXPLICACIÓN TÉCNICA

A las 09:11:00 se registró un script block de PowerShell con 'Get-LocalGroupMember Administrators; Get-SmbShare' (EVT-00207) y a las 09:13:00 se ejecutó 'net.exe view \\FS-SRV01' con padre powershell.exe (EVT-00214), bajo CORP\admin y con origen 198.51.100.77. Es consistente con enumeración de administradores y recursos compartidos (T1087, T1069, T1135).

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00207** | 09:11:00 | APP-SRV01 | admin | 198.51.100.77 | 4104 · powershell.exe | High |
| **EVT-00214** | 09:13:00 | APP-SRV01 | admin | 198.51.100.77 | 4688 · net.exe view \\FS-SRV01 | Medium |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

El atacante obtuvo, o pudo obtener, información sobre administradores locales y recursos compartidos para elegir objetivos.

### PLAN DE ACCIÓN

**Investigar**
- Revisar la salida o el alcance de la enumeración, que no consta en los logs.
- Buscar otros comandos de descubrimiento en APP-SRV01 y FS-SRV01.

**Contener**
- Mantener APP-SRV01 aislado y limitar los accesos de CORP\admin.

**Remediar**
- Restringir la enumeración de recursos compartidos y la pertenencia a grupos administrativos.
- Crear alertas para net.exe view y Get-SmbShare lanzados desde sesiones remotas.

## CRÍTICO F-009 Movimiento lateral de admin: APP-SRV01 -> FS-SRV01

Movimiento lateral · Movimiento lateral · MITRE ATT&CK (orientativo): T1021.002, T1078 · 09:15:00–09:16:00 · 2 eventos

### CRITICIDAD Y JUSTIFICACIÓN

Crítico: salto a un segundo servidor con una cuenta ya comprometida (EVT-00188), con un fallo previo en la misma secuencia.

### EXPLICACIÓN TÉCNICA

En FS-SRV01 hubo un fallo (EVT-00222, 09:15:00) y un éxito (EVT-00225, 09:16:00) de autenticación de red (LogonType=3) de CORP\admin con origen APP-SRV01 (10.10.2.15). Es consistente con movimiento lateral con cuentas válidas (T1021.002, T1078) desde un host ya comprometido.

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00222** | 09:15:00 | FS-SRV01 | admin | 10.10.2.15 | 4625 · An account failed to log on (LogonType=3; source=APP-SRV01) | Medium |
| **EVT-00225** | 09:16:00 | FS-SRV01 | admin | 10.10.2.15 | 4624 · An account was successfully logged on (LogonType=3; source=APP-SRV01) | High |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

El compromiso se extiende al servidor de ficheros FS-SRV01, que aloja datos sensibles.

### PLAN DE ACCIÓN

**Investigar**
- Revisar la actividad de CORP\admin en FS-SRV01 después de las 09:16:00.
- Buscar otros destinos de autenticación desde APP-SRV01 con esta cuenta.

**Contener**
- Aislar FS-SRV01 o restringir su acceso por red desde APP-SRV01.
- Deshabilitar CORP\admin.

**Remediar**
- Segmentar la red entre servidores de aplicación y de ficheros.
- Rotar las credenciales de cuentas con sesión en ambos servidores y limitar el uso de cuentas administrativas compartidas.

## ALTO F-010 Acceso a recurso sensible 'finance' por admin

Otras anomalías · Recolección · MITRE ATT&CK (orientativo): T1039 · 09:17:00–09:18:00 · 2 eventos

### CRITICIDAD Y JUSTIFICACIÓN

Alto: acceso a un recurso de contenido financiero por una cuenta comprometida, con eventos que el SIEM marcó como High.

### EXPLICACIÓN TÉCNICA

CORP\admin accedió al recurso \\FS-SRV01\Finance a las 09:17:00 (EVT-00227) y a Finance\Budget2027.xlsx a las 09:18:00 (EVT-00231), desde 10.10.2.15. Los logs muestran el acceso, pero no confirman copia ni lectura del contenido del archivo (no hay evidencia en los logs).

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00227** | 09:17:00 | FS-SRV01 | admin | 10.10.2.15 | 5140 · Network share accessed: \\FS-SRV01\Finance | High |
| **EVT-00231** | 09:18:00 | FS-SRV01 | admin | 10.10.2.15 | 5145 · Detailed file share access: Finance\Budget2027.xlsx | High |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Posible exposición de información financiera confidencial, como Budget2027.xlsx.

### PLAN DE ACCIÓN

**Investigar**
- Revisar en FS-SRV01 qué archivos de Finance se abrieron, copiaron o modificaron en esa ventana.
- Comprobar si el acceso de CORP\admin a este recurso era habitual, porque no hay línea base.

**Contener**
- Restringir temporalmente el acceso al recurso Finance y preservar los logs de acceso.

**Remediar**
- Revisar ACL del recurso Finance y retirar el acceso de cuentas administrativas genéricas.
- Habilitar auditoría detallada de acceso a ficheros sensibles.

## CRÍTICO F-011 Compresión de datos (staging) en APP-SRV01 (admin)

Comandos y procesos · Recolección · MITRE ATT&CK (orientativo): T1560.001, T1074.001 · 09:20:00–09:20:00 · 1 evento

### CRITICIDAD Y JUSTIFICACIÓN

Crítico: compresión de datos tras acceder a Finance y 1 minuto antes de una conexión saliente a una IP externa, en una sesión de origen externo.

### EXPLICACIÓN TÉCNICA

A las 09:20:00 se ejecutó en APP-SRV01, bajo CORP\admin, el comando 'tar.exe -a -c -f C:\Temp\finance.zip C:\Temp\reports' (EVT-00232) para comprimir C:\Temp\reports. El log muestra la ejecución, no que finance.zip se creara ni su contenido. Es consistente con staging previo a exfiltración (T1560.001, T1074.001).

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00232** | 09:20:00 | APP-SRV01 | admin | 198.51.100.77 | 4688 · tar.exe -a -c -f C:\Temp\finance.zip C:\Temp\reports | High |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Posible preparación de datos financieros para su extracción.

### PLAN DE ACCIÓN

**Investigar**
- Verificar si existe C:\Temp\finance.zip en APP-SRV01 y qué contiene C:\Temp\reports.
- Determinar cómo llegaron datos de Finance a APP-SRV01, porque no hay evidencia en los logs de una copia.

**Contener**
- Preservar y aislar el archivo y el host antes de eliminar nada.

**Remediar**
- Eliminar los artefactos tras el análisis forense.
- Monitorizar tar.exe, zip y 7z lanzados desde sesiones remotas y por cuentas administrativas.

## CRÍTICO F-012 Conexión saliente a IP externa 203.0.113.88 desde APP-SRV01

Otras anomalías · Comando y control · MITRE ATT&CK (orientativo): T1071.001, T1041 · 09:21:00–09:21:00 · 1 evento

### CRITICIDAD Y JUSTIFICACIÓN

Crítico: conexión iniciada por un intérprete de comandos hacia una IP externa, justo después del staging y con una cuenta comprometida.

### EXPLICACIÓN TÉCNICA

A las 09:21:00 el firewall registró una conexión saliente permitida de APP-SRV01 (10.10.2.15) a 203.0.113.88:443 iniciada por powershell.exe bajo CORP\admin (EVT-00235), 1 minuto después del comando de compresión. Es consistente con exfiltración o canal C2 sobre HTTPS (T1071.001, T1041), pero una conexión permitida no prueba transferencia de datos y no hay evidencia en los logs del volumen enviado.

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00235** | 09:21:00 | APP-SRV01 | admin | 10.10.2.15 | 5156 · powershell.exe | High |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Posible salida de datos financieros o presencia de un canal de mando y control activo.

### PLAN DE ACCIÓN

**Investigar**
- Obtener del firewall o proxy el volumen de bytes y la duración de la conexión a 203.0.113.88.
- Buscar otras conexiones desde la red del cliente hacia 203.0.113.88 y revisar eventos posteriores a las 09:21:00.

**Contener**
- Bloquear 203.0.113.88 en firewall y proxy.
- Aislar APP-SRV01 de la red.

**Remediar**
- Aplicar filtrado de salida para servidores, permitiendo solo destinos necesarios.
- Si se confirma exfiltración, activar el proceso de respuesta y notificación por datos financieros.

## CRÍTICO INC-003 Recolección masiva en Finance y eliminación de copias de sombra con la cuenta backupsvc (WS-023 / FS-SRV01)

2026-10-23 09:36:00 a 09:43:00 · Hosts: WS-023, FS-SRV01 · Cuentas: backupsvc

Entre las 09:36:00 y las 09:43:00 la cuenta CORP\backupsvc, con IP de origen 10.10.1.44, realizó una secuencia de acciones en WS-023 y FS-SRV01. En WS-023 se ejecutó PowerShell con -EncodedCommand (EVT-00280). Después, entre 09:37:00 y 09:41:00, la cuenta accedió con éxito a 16 archivos consecutivos (document_000.xlsx a document_015.xlsx) en \\FS-SRV01\Finance (EVT-00284 a EVT-00309). A las 09:43:00 se registró una comprobación de acceso al recurso compartido Finance (EVT-00315). A las 09:42:00 se ejecutó en WS-023 el comando vssadmin.exe delete shadows /all /quiet (EVT-00314). La secuencia sugiere recolección de datos seguida de acciones anti-recuperación, un patrón consistente con preparación de ransomware o exfiltración. Los logs no prueban el resultado del borrado de copias, el contenido del script codificado ni la transferencia de datos. La relación con INC-002 es una hipótesis de baja confianza.

**Confianza de la agrupación:** Media. La cuenta, la IP de origen (10.10.1.44) y la ventana de 7 minutos son coherentes entre los tres hallazgos, y los comandos y accesos están registrados con éxito. Pero no hay evidencia en los logs del contenido del script codificado, del resultado del borrado de copias, de transferencia de datos ni del origen del uso de la cuenta. Tampoco hay línea base de la cuenta de servicio. Los eventos 4688 de WS-023 y los 4663 de FS-SRV01 no muestran un vínculo de proceso directo entre ellos.

### CRONOLOGÍA

| Hora | Paso | Evidencia |
|---|---|---|
| 09:36:00 | En WS-023, backupsvc ejecuta PowerShell con -EncodedCommand. El contenido del script no está disponible (redactado). | EVT-00280 |
| 09:37:00 | Inicia el acceso exitoso a archivos de \\FS-SRV01\Finance, con numeración consecutiva desde document_000.xlsx. | EVT-00284, EVT-00286, EVT-00289 |
| 09:41:00 | Último acceso del barrido: document_015.xlsx. En total, 16 archivos en unos 4 minutos. | EVT-00309 |
| 09:42:00 | En WS-023 se ejecuta el comando vssadmin.exe delete shadows /all /quiet para eliminar copias de sombra. | EVT-00314 |
| 09:43:00 | Evento 5145 de comprobación de acceso al recurso compartido Finance por backupsvc, con resultado Success. | EVT-00315 |

## ALTO F-013 PowerShell con comando codificado en WS-023 (backupsvc)

Comandos y procesos · Ejecución · MITRE ATT&CK (orientativo): T1059.001, T1027 · 09:36:00–09:36:00 · 1 evento

### CRITICIDAD Y JUSTIFICACIÓN

El motor lo clasificó como Alto porque coincide con el patrón de PowerShell con comando codificado, que oculta el script. La ejecución terminó con Success y se hizo con una cuenta de servicio. A los pocos minutos le siguieron un acceso masivo y el borrado de copias de sombra.

### EXPLICACIÓN TÉCNICA

En WS-023, CORP\backupsvc (IP 10.10.1.44) creó un proceso con la línea de comandos powershell.exe -NoProfile -EncodedCommand <base64_redacted> a las 09:36:00 (EVT-00280, evento 4688, Success). El parámetro -EncodedCommand oculta el contenido del script y se usa para evadir controles. El contenido decodificado no figura en los logs (no hay evidencia en los logs). Es el primer evento de la secuencia.

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00280** | 09:36:00 | WS-023 | backupsvc | 10.10.1.44 | 4688 · powershell.exe -NoProfile -EncodedCommand <base64_redacted> | Warning |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Ejecución de código no visible en una estación de trabajo con una cuenta con privilegios de respaldo. Esto puede habilitar las acciones posteriores del incidente y dificulta saber qué hizo realmente el script.

### PLAN DE ACCIÓN

| Investigar | Contener | Remediar |
|---|---|---|
| • Recuperar y decodificar el comando base64 de EVT-00280 desde el origen (Script Block Logging 4104, si está habilitado) o desde EDR.<br>• Identificar el proceso padre y el origen de la sesión de backupsvc en WS-023 desde 10.10.1.44.<br>• Revisar otros procesos hijos y conexiones de red de ese PowerShell en torno a las 09:36. | • Aislar WS-023 de la red mientras se investiga.<br>• Deshabilitar o restablecer temporalmente las credenciales de CORP\backupsvc y cerrar sus sesiones activas. | • Rotar la contraseña de backupsvc y revisar sus privilegios y los lugares donde se usa.<br>• Activar o reforzar el registro de PowerShell (Script Block y Module Logging) y alertar sobre -EncodedCommand.<br>• Aplicar restricciones como Constrained Language Mode o AppLocker/WDAC para cuentas de servicio. |

## ALTO F-014 Acceso masivo a archivos por backupsvc en FS-SRV01

Otras anomalías · Recolección · MITRE ATT&CK (orientativo): T1039, T1005 · 09:37:00–09:43:00 · 17 eventos

### CRITICIDAD Y JUSTIFICACIÓN

El motor lo clasificó como Alto por tres motivos: 16 accesos en 4 min con numeración consecutiva, típica de automatización, sobre un recurso sensible (finance). Ocurrió justo después del PowerShell codificado y antes del borrado de copias de sombra.

### EXPLICACIÓN TÉCNICA

Entre las 09:37:00 y las 09:41:00, CORP\backupsvc (IP 10.10.1.44) registró 16 eventos 4663 con resultado Success sobre \\FS-SRV01\Finance. Los archivos fueron Finance\FY2026\document_000.xlsx a document_015.xlsx (EVT-00284, 00286, 00289, 00290, 00291, 00293, 00296, 00298, 00300, 00302, 00303, 00305, 00306, 00307, 00308, 00309). El ritmo fue de unos 4 archivos por minuto (un archivo cada 16 s aproximadamente) y con numeración consecutiva, lo que es consistente con un recorrido automatizado. A las 09:43:00 el evento 5145 (EVT-00315) registró una comprobación de acceso al recurso compartido Finance por la misma cuenta. Esto sugiere recolección (T1039), pero los logs no prueban copia ni transferencia de datos (no hay evidencia en los logs).

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00284** | 09:37:00 | FS-SRV01 | backupsvc | 10.10.1.44 | 4663 · File access: Finance\FY2026\document_000.xlsx | Warning |
| **EVT-00286** | 09:37:16 | FS-SRV01 | backupsvc | 10.10.1.44 | 4663 · File access: Finance\FY2026\document_001.xlsx | Warning |
| **EVT-00289** | 09:37:32 | FS-SRV01 | backupsvc | 10.10.1.44 | 4663 · File access: Finance\FY2026\document_002.xlsx | Warning |
| **EVT-00290** | 09:37:48 | FS-SRV01 | backupsvc | 10.10.1.44 | 4663 · File access: Finance\FY2026\document_003.xlsx | Warning |
| **EVT-00291** | 09:38:04 | FS-SRV01 | backupsvc | 10.10.1.44 | 4663 · File access: Finance\FY2026\document_004.xlsx | Warning |
| **EVT-00293** | 09:38:20 | FS-SRV01 | backupsvc | 10.10.1.44 | 4663 · File access: Finance\FY2026\document_005.xlsx | Warning |
| **EVT-00296** | 09:38:36 | FS-SRV01 | backupsvc | 10.10.1.44 | 4663 · File access: Finance\FY2026\document_006.xlsx | Warning |
| **EVT-00298** | 09:38:52 | FS-SRV01 | backupsvc | 10.10.1.44 | 4663 · File access: Finance\FY2026\document_007.xlsx | Warning |
| **EVT-00300** | 09:39:08 | FS-SRV01 | backupsvc | 10.10.1.44 | 4663 · File access: Finance\FY2026\document_008.xlsx | Warning |
| **EVT-00309** | 09:41:00 | FS-SRV01 | backupsvc | 10.10.1.44 | 4663 · File access: Finance\FY2026\document_015.xlsx | Warning |
| **EVT-00315** | 09:43:00 | FS-SRV01 | backupsvc | 10.10.1.44 | 5145 · A network share object was checked to see whether client can be granted desired access | Informational |

Se muestran 11 de 17 eventos (primeros 9 y últimos 2). Rango completo: EVT-00284 a EVT-00315. IDs completos: EVT-00284, EVT-00286, EVT-00289, EVT-00290, EVT-00291, EVT-00293, EVT-00296, EVT-00298, EVT-00300, EVT-00302, EVT-00303, EVT-00305, EVT-00306, EVT-00307, EVT-00308, EVT-00309, EVT-00315

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Posible exposición de datos financieros (Finance\FY2026) si el acceso fue de lectura con fines de exfiltración o preparación de cifrado. El alcance real de la lectura o copia no se puede confirmar con estos logs.

### PLAN DE ACCIÓN

| Investigar | Contener | Remediar |
|---|---|---|
| • Determinar si la cuenta backupsvc accede normalmente a Finance y si hay una tarea de respaldo legítima en ese horario.<br>• Revisar el tipo de acceso (lectura, copia) en los eventos 4663 originales y el tráfico de red saliente desde 10.10.1.44 y FS-SRV01 tras las 09:41.<br>• Comprobar si hay más archivos o carpetas accedidos fuera de estos 16, y si los archivos han sido modificados o cifrados.<br>• Evaluar la relación con INC-002, que también tocó Finance (H-01, baja confianza), sin asumir un vínculo. | • Bloquear el acceso de backupsvc a \\FS-SRV01\Finance.<br>• Vigilar o restringir temporalmente el acceso a la carpeta Finance en FS-SRV01 y preservar sus copias fuera de línea. | • Aplicar mínimo privilegio a las cuentas de servicio de respaldo, limitadas a hosts y horarios definidos.<br>• Habilitar alertas de acceso masivo a recursos sensibles.<br>• Si se confirma exposición, evaluar las obligaciones de notificación sobre los datos financieros. |

## CRÍTICO F-015 Eliminación de copias de sombra (anti-recuperación) en WS-023 (backupsvc)

Comandos y procesos · Impacto · MITRE ATT&CK (orientativo): T1490 · 09:42:00–09:42:00 · 1 evento

### CRITICIDAD Y JUSTIFICACIÓN

Crítico, según el motor, porque coincide con el patrón de eliminación de copias de sombra, que impide restaurar archivos y suele preceder a un ransomware. Se ejecutó con éxito, con la misma cuenta, justo después del barrido de archivos de Finance y de un PowerShell codificado.

### EXPLICACIÓN TÉCNICA

A las 09:42:00, en WS-023, CORP\backupsvc (IP 10.10.1.44) ejecutó vssadmin.exe delete shadows /all /quiet (EVT-00314, evento 4688, Success). Se ejecutó el comando para eliminar todas las copias de sombra de forma silenciosa. El log registra la creación del proceso, no el resultado del borrado. Ese comando es consistente con una técnica anti-recuperación (T1490).

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00314** | 09:42:00 | WS-023 | backupsvc | 10.10.1.44 | 4688 · vssadmin.exe delete shadows /all /quiet | Warning |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Si el comando tuvo efecto, se pierde la capacidad de recuperar archivos desde copias de sombra de WS-023. Dentro de la secuencia, esto es consistente con la preparación de un evento de cifrado o destrucción de datos.

### PLAN DE ACCIÓN

| Investigar | Contener | Remediar |
|---|---|---|
| • Verificar en WS-023 si las copias de sombra siguen existiendo (vssadmin list shadows) y revisar los eventos de VSS.<br>• Buscar actividad de cifrado, creación de notas de rescate o modificación masiva de archivos en WS-023 y FS-SRV01 después de las 09:42.<br>• Revisar si hubo comandos similares en otros hosts con backupsvc. | • Aislar WS-023 y mantener la cuenta backupsvc deshabilitada.<br>• Proteger o desconectar las copias de seguridad fuera de línea o inmutables para evitar su afectación.<br>• Considerar el aislamiento preventivo de FS-SRV01 si hay indicios de cifrado. | • Restaurar los servicios afectados desde respaldos verificados una vez erradicada la amenaza.<br>• Alertar sobre vssadmin delete shadows, wmic shadowcopy delete y bcdedit en la detección.<br>• Restringir qué cuentas pueden administrar VSS y revisar las credenciales de las cuentas de servicio. |

Observación relacionada: F-024 — Cuentas con nombres casi idénticos: backupsvc / svc_backup (ver sección 5).

## INC-004 Posible exfiltración por HTTPS de ~253,3 MB desde WS-018 (CORP\rrojas) hacia 198.51.100.88 tras acceso a recurso Legal y compresión de datos

CRÍTICO

2026-10-23 10:40:00 a 10:49:18 · Hosts: FS-SRV01, WS-018 · IP externas: 198.51.100.88 · Cuentas: rrojas

El 2026-10-23, entre las 10:40:00 y las 10:49:18, la cuenta CORP\rrojas accedió al recurso compartido \\FS-SRV01\Legal (EVT-00419) desde la IP 10.10.1.31. A las 10:42:00 se ejecutó en WS-018 el comando 7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx (EVT-00428), que corresponde a una compresión de documentos. Desde las 10:43:00 hasta las 10:49:18 el proxy registró 22 HTTPS POST permitidos hacia 198.51.100.88:443, con URIs /upload/session/1 a /upload/session/22 y 253.305.558 bytes salientes en total (EVT-00430 a EVT-00461), a intervalos regulares de unos 18 s. La secuencia es consistente con recolección, preparación y exfiltración de datos (T1039, T1560.001, T1074.001, T1041). Los logs no muestran el contenido enviado ni confirman que lo transferido sea archive.7z. Tampoco hay evidencia en los logs del vector que dio acceso a la cuenta ni de si la actividad fue autorizada.

**Confianza de la agrupación:** Media. La secuencia temporal (acceso a Legal, compresión, subidas periódicas con volumen elevado a una IP externa) es coherente y está respaldada por logs de Security y Proxy del mismo usuario, host e IP de origen. Sin embargo, no hay evidencia en los logs del contenido enviado, de la existencia de archive.7z, del vínculo entre C:\Legal y \\FS-SRV01\Legal, del vector de acceso ni de la autorización de la actividad. La reputación de 198.51.100.88 tampoco se evaluó. La hipótesis H-03 sobre INC-002 es de confianza Baja.

### CRONOLOGÍA

| Hora | Paso | Evidencia |
|---|---|---|
| 10:40:00 | CORP\rrojas accede al recurso compartido \\FS-SRV01\Legal (Event_ID 5140, Success) desde 10.10.1.31. | EVT-00419 |
| 10:42:00 | En WS-018 se ejecuta el comando 7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx, orientado a comprimir documentos (staging). El log prueba la ejecución, no la creación del archivo. | EVT-00428 |
| 10:43:00 | Comienza la serie de HTTPS POST permitidos desde WS-018 hacia 198.51.100.88:443 (/upload/session/1, 6.737.085 bytes salientes), 1 min después de la compresión. | EVT-00430 |
| 10:43:18 | Continúan las subidas por sesiones numeradas (sesiones 2 a 21) con cadencia de 18 s, hasta las 10:49:00. | EVT-00431, EVT-00432, EVT-00435, EVT-00436 … (+16) |
| 10:49:18 | Última petición registrada (/upload/session/22, 16.778.302 bytes). El total acumulado es de 22 POST y 253.305.558 bytes (253,3 MB) en 6 min 18 s. | EVT-00461 |

## MEDIO F-016 Acceso a recurso sensible 'legal' por rrojas

Otras anomalías · Recolección · MITRE ATT&CK (orientativo): T1039 · 10:40:00–10:40:00 · 1 evento

### CRITICIDAD Y JUSTIFICACIÓN

Severidad Media, decidida por el motor: es un acceso de lectura a un recurso de contenido sensible ('legal') por parte de CORP\rrojas, con un solo evento. Por sí solo no prueba abuso. Su peso depende de la actividad posterior de compresión y envío al exterior.

### EXPLICACIÓN TÉCNICA

A las 10:40:00, CORP\rrojas accedió con éxito al recurso compartido \\FS-SRV01\Legal (Event_ID 5140, origen 10.10.1.31) según EVT-00419. Es un único evento de lectura. Su relevancia se interpreta por lo que ocurre después: a los 2 min se ejecuta una compresión de documentos (EVT-00428). Los logs no indican qué archivos se leyeron dentro del recurso. No hay evidencia en los logs de que C:\Legal en WS-018 corresponda a este recurso compartido.

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00419** | 10:40:00 | FS-SRV01 | rrojas | 10.10.1.31 | 5140 · A network share object was accessed | Informational |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Posible exposición de documentos legales confidenciales si el acceso no estaba autorizado o fue usado como paso previo a la exfiltración.

### PLAN DE ACCIÓN

| Investigar | Contener | Remediar |
|---|---|---|
| • Confirmar con el negocio si rrojas tiene necesidad legítima de acceder a \\FS-SRV01\Legal.<br>• Revisar en FS-SRV01 el detalle de acceso a archivos (si está auditado) para determinar qué ficheros se leyeron o copiaron.<br>• Verificar si la ruta C:\Legal de WS-018 es una copia local o un mapeo del recurso compartido. | • Valorar restringir temporalmente el acceso de CORP\rrojas al recurso Legal mientras se aclara el incidente. | • Revisar y aplicar mínimo privilegio en los permisos del recurso Legal.<br>• Habilitar o confirmar la auditoría detallada de acceso a archivos en FS-SRV01. |

## ALTO F-017 Compresión de datos (staging) en WS-018 (rrojas)

Comandos y procesos · Recolección · MITRE ATT&CK (orientativo): T1560.001, T1074.001 · 10:42:00–10:42:00 · 1 evento

### CRITICIDAD Y JUSTIFICACIÓN

Severidad Alta, decidida por el motor: el comando coincide con el patrón de compresión de datos (staging, T1560.001 y T1074.001), que suele preceder a la exfiltración. Aquí además se orienta a documentos de una ruta 'Legal' y se ubica en C:\Users\Public. Se mantiene en Alta, y no en Crítica, porque el log solo prueba la ejecución del comando.

### EXPLICACIÓN TÉCNICA

A las 10:42:00 se registró en WS-018 un proceso creado por CORP\rrojas (Event_ID 4688) con la línea de comandos 7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx (EVT-00428). Se ejecutó el comando para comprimir los .docx de C:\Legal en un archivo 7z dentro de una carpeta pública. Los logs no confirman que archive.7z se haya creado ni su tamaño. Esta compresión precede 1 min a las subidas al proxy (EVT-00430).

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00428** | 10:42:00 | WS-018 | rrojas | 10.10.1.31 | 4688 · 7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx | Informational |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Agrupación de documentos legales en un único archivo, lo que facilita su extracción y puede indicar preparación de una fuga de información.

### PLAN DE ACCIÓN

| Investigar | Contener | Remediar |
|---|---|---|
| • Comprobar en WS-018 si existe C:\Users\Public\archive.7z, su tamaño, hash y fecha de creación.<br>• Identificar el proceso padre de 7z.exe y cómo se instaló o dónde reside el binario (no hay evidencia en los logs).<br>• Determinar si el contenido del archivo coincide con lo enviado en las subidas de EVT-00430 a EVT-00461. | • Aislar WS-018 de la red tras preservar evidencia volátil y forense.<br>• Conservar una copia de archive.7z antes de cualquier borrado. | • Eliminar archive.7z y cualquier artefacto de staging tras el análisis forense.<br>• Valorar reglas de detección o bloqueo de herramientas de compresión ejecutadas sobre rutas sensibles o escritas en C:\Users\Public. |

## CRÍTICO F-018 Posible exfiltración de 253,3 MB desde WS-018 hacia 198.51.100.88

Otras anomalías · Exfiltración · MITRE ATT&CK (orientativo): T1041 · 10:43:00–10:49:18 · 22 eventos

### CRITICIDAD Y JUSTIFICACIÓN

Severidad Crítica, decidida por el motor: gran volumen (253,3 MB) hacia una IP externa en pocos minutos, cadencia regular, URIs de subida por sesiones numeradas y secuencia directa tras acceso a recurso Legal y compresión de datos del mismo usuario y host. Es consistente con exfiltración por HTTPS (T1041), aunque la transferencia de datos sensibles concretos no está demostrada por los logs.

### EXPLICACIÓN TÉCNICA

Entre las 10:43:00 y las 10:49:18, el proxy registró 22 HTTPS POST salientes y permitidos (Result Allowed) desde WS-018 (10.10.1.31, usuario CORP\rrojas) hacia 198.51.100.88:443, con URIs /upload/session/1 a /upload/session/22 (EVT-00430 a EVT-00461). La suma de bytes_out es 253.305.558 bytes (253,3 MB) en 378 s (6 min 18 s). La mediana entre peticiones es de 18 s, una cadencia regular consistente con una transferencia automatizada. Comenzó 1 min después de EVT-00428. El proxy registra bytes salientes y que la petición fue permitida. No hay evidencia en los logs del contenido enviado ni de la respuesta del destino.

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00430** | 10:43:00 | WS-018 | rrojas | 10.10.1.31 | PROXY_ACCESS · bytes_out=6737085 uri=/upload/session/1 | Warning |
| **EVT-00431** | 10:43:18 | WS-018 | rrojas | 10.10.1.31 | PROXY_ACCESS · bytes_out=17278017 uri=/upload/session/2 | Warning |
| **EVT-00432** | 10:43:36 | WS-018 | rrojas | 10.10.1.31 | PROXY_ACCESS · bytes_out=13916972 uri=/upload/session/3 | Warning |
| **EVT-00435** | 10:43:54 | WS-018 | rrojas | 10.10.1.31 | PROXY_ACCESS · bytes_out=16895186 uri=/upload/session/4 | Warning |
| **EVT-00436** | 10:44:12 | WS-018 | rrojas | 10.10.1.31 | PROXY_ACCESS · bytes_out=7196949 uri=/upload/session/5 | Warning |
| **EVT-00438** | 10:44:30 | WS-018 | rrojas | 10.10.1.31 | PROXY_ACCESS · bytes_out=14427680 uri=/upload/session/6 | Warning |
| **EVT-00439** | 10:44:48 | WS-018 | rrojas | 10.10.1.31 | PROXY_ACCESS · bytes_out=10427823 uri=/upload/session/7 | Warning |
| **EVT-00440** | 10:45:06 | WS-018 | rrojas | 10.10.1.31 | PROXY_ACCESS · bytes_out=12043158 uri=/upload/session/8 | Warning |
| **EVT-00441** | 10:45:24 | WS-018 | rrojas | 10.10.1.31 | PROXY_ACCESS · bytes_out=6167521 uri=/upload/session/9 | Warning |
| **EVT-00460** | 10:49:00 | WS-018 | rrojas | 10.10.1.31 | PROXY_ACCESS · bytes_out=13316765 uri=/upload/session/21 | Warning |
| **EVT-00461** | 10:49:18 | WS-018 | rrojas | 10.10.1.31 | PROXY_ACCESS · bytes_out=16778302 uri=/upload/session/22 | Warning |

Se muestran 11 de 22 eventos (primeros 9 y últimos 2). Rango completo: EVT-00430 a EVT-00461. IDs completos: EVT-00430, EVT-00431, EVT-00432, EVT-00435, EVT-00436, EVT-00438, EVT-00439, EVT-00440, EVT-00441, EVT-00443, EVT-00444, EVT-00445, EVT-00448, EVT-00450, EVT-00451, EVT-00453, EVT-00455, EVT-00456, EVT-00457, EVT-00458, EVT-00460, EVT-00461

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Posible fuga de documentos legales confidenciales a un destino externo, con consecuencias de confidencialidad, regulatorias y contractuales. El alcance real depende del contenido enviado, que no consta en los logs.

## PLAN DE ACCIÓN

| Investigar | Contener | Remediar |
|---|---|---|
| • Determinar con el proxy o un captura de tráfico el contenido y destino real de las sesiones 1 a 22 y si la IP 198.51.100.88 tiene otras conexiones en el entorno.<br>• Identificar el proceso de WS-018 que originó los POST (no hay evidencia en los logs) y revisar telemetría de endpoint.<br>• Verificar el origen de la sesión de CORP\rrojas (inicio de sesión, posibles credenciales comprometidas) y si el usuario reconoce la actividad.<br>• Buscar otros hosts o usuarios que se comuniquen con 198.51.100.88 o con el resto de 198.51.100.0/24. La hipótesis H-03 con INC-002 es solo una coincidencia de /24 de confianza Baja y no prueba infraestructura común. | • Bloquear 198.51.100.88 en proxy y firewall.<br>• Aislar WS-018 y restringir las sesiones de CORP\rrojas; restablecer sus credenciales y revocar sesiones activas.<br>• Alertar al equipo legal o de cumplimiento para evaluar la notificación del posible incidente de datos. | • Revisar políticas de proxy para limitar subidas voluminosas a destinos no categorizados o desconocidos y alertar sobre POST repetitivos.<br>• Implementar DLP o monitorización sobre repositorios sensibles como Legal.<br>• Una vez concluido el análisis, reconstruir WS-018 si se confirma compromiso. |

ALTO

## INC-005 Persistencia en APP-SRV01 mediante tarea programada y servicio creados por CORP\helpdesk

2026-10-23 11:37:00 a 12:04:00 · Hosts: APP-SRV01 · Cuentas: helpdesk

El 2026-10-23, entre las 11:37:00 y las 12:04:00, la cuenta CORP\helpdesk (Source_IP 10.10.3.18) creó en APP-SRV01 una tarea programada "\Microsoft\Windows\UpdateCheck" que ejecuta powershell.exe -File C:\ProgramData\updatecheck.ps1 (EVT-00523). Un minuto después instaló el servicio "WinUpdateHelper" con ImagePath C:\ProgramData\wuhelper.exe (EVT-00524). Posteriormente se registraron cinco creaciones de proceso de C:\ProgramData\wuhelper.exe a las 11:40, 11:46, 11:52, 11:58 y 12:04, con intervalo regular de 6 minutos (EVT-00528, EVT-00542, EVT-00548, EVT-00559, EVT-00564). Los nombres imitan componentes de Windows y las rutas están en ProgramData, ubicación escribible. Esto es consistente con persistencia y enmascaramiento; no hay evidencia en los logs sobre el contenido de los binarios/scripts, el origen de la cuenta ni comunicaciones de red asociadas.

**Confianza de la agrupación:** Media. Los eventos 4698, 7045 y 4688 muestran de forma directa la creación de la tarea, del servicio y las ejecuciones periódicas desde ProgramData con nombres que imitan a Windows. Sin embargo, no hay evidencia en los logs sobre el contenido de los binarios, el proceso padre, la actividad de red ni el origen del uso de la cuenta (legítimo o comprometido); tampoco hay línea base.

### CRONOLOGÍA

| Hora | Paso | Evidencia |
|---|---|---|
| 11:37:00 | CORP\helpdesk crea la tarea programada \Microsoft\Windows\UpdateCheck que ejecuta powershell.exe -File C:\ProgramData\updatecheck.ps1 (Persistencia). | EVT-00523 |
| 11:38:00 | CORP\helpdesk instala el servicio WinUpdateHelper con ImagePath C:\ProgramData\wuhelper.exe. | EVT-00524 |
| 11:40:00 | Primera ejecución registrada de C:\ProgramData\wuhelper.exe. | EVT-00528 |
| 11:46:00 | Segunda ejecución de wuhelper.exe (6 min después). | EVT-00542 |
| 11:52:00 | Tercera ejecución de wuhelper.exe. | EVT-00548 |
| 11:58:00 | Cuarta ejecución de wuhelper.exe. | EVT-00559 |
| 12:04:00 | Quinta ejecución de wuhelper.exe, manteniendo el intervalo periódico de 6 minutos. | EVT-00564 |

## ALTO F-019 Persistencia en APP-SRV01 mediante tarea programada y servicio

Otras anomalías · Persistencia · MITRE ATT&CK (orientativo): T1053.005, T1543.003, T1036.004 · 11:37:00–12:04:00 · 7 eventos

### CRITICIDAD Y JUSTIFICACIÓN

Severidad Alto asignada por el motor: una cuenta no administrativa (helpdesk) realizó operaciones privilegiadas en un servidor (EVT-00523, EVT-00524); se crearon dos mecanismos de persistencia distintos; binario y script residen en ProgramData; los nombres enmascaran componentes de Windows; y el binario se ejecutó 5 veces tras instalarse con periodicidad de 6 min (EVT-00528 a EVT-00564).

### EXPLICACIÓN TÉCNICA

En APP-SRV01, CORP\helpdesk creó una tarea programada \Microsoft\Windows\UpdateCheck con acción powershell.exe -File C:\ProgramData\updatecheck.ps1 (EVT-00523, Event_ID 4698, 11:37:00) y un minuto después instaló el servicio WinUpdateHelper con ImagePath C:\ProgramData\wuhelper.exe (EVT-00524, Event_ID 7045, 11:38:00); ambos con Result Success. Luego se registraron cinco creaciones de proceso de C:\ProgramData\wuhelper.exe (EVT-00528, EVT-00542, EVT-00548, EVT-00559, EVT-00564) a intervalos de 6 minutos (360 s). Es sospechoso porque ProgramData es una ruta escribible no estándar para binarios de sistema y los nombres (ruta \Microsoft\Windows, UpdateCheck, WinUpdateHelper) imitan componentes legítimos. La periodicidad sugiere un comportamiento tipo beacon o ejecución programada. Es consistente con T1053.005, T1543.003 y T1036.004. No hay evidencia en los logs de la ejecución de updatecheck.ps1 ni de su contenido, ni de conexiones de red de wuhelper.exe.

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00523** | 11:37:00 | APP-SRV01 | helpdesk | 10.10.3.18 | 4698 · TaskName=\Microsoft\Windows\UpdateCheck; Action=powershell.exe -File C:\ProgramData\updatechec… | Warning |
| **EVT-00524** | 11:38:00 | APP-SRV01 | helpdesk | 10.10.3.18 | 7045 · ServiceName=WinUpdateHelper; ImagePath=C:\ProgramData\wuhelper.exe | Warning |
| **EVT-00528** | 11:40:00 | APP-SRV01 | helpdesk | 10.10.3.18 | 4688 · C:\ProgramData\wuhelper.exe | Informational |
| **EVT-00542** | 11:46:00 | APP-SRV01 | helpdesk | 10.10.3.18 | 4688 · C:\ProgramData\wuhelper.exe | Informational |
| **EVT-00548** | 11:52:00 | APP-SRV01 | helpdesk | 10.10.3.18 | 4688 · C:\ProgramData\wuhelper.exe | Informational |
| **EVT-00559** | 11:58:00 | APP-SRV01 | helpdesk | 10.10.3.18 | 4688 · C:\ProgramData\wuhelper.exe | Informational |
| **EVT-00564** | 12:04:00 | APP-SRV01 | helpdesk | 10.10.3.18 | 4688 · C:\ProgramData\wuhelper.exe | Informational |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Posible acceso persistente en APP-SRV01 que sobrevive a reinicios y permite ejecución recurrente de código no verificado con la cuenta CORP\helpdesk. Si la cuenta está comprometida, podría facilitar control remoto, movimiento lateral o acciones adicionales. El impacto concreto no puede confirmarse con los logs disponibles.

## PLAN DE ACCIÓN

| Investigar | Contener | Remediar |
|---|---|---|
| • Obtener y analizar C:\ProgramData\wuhelper.exe y C:\ProgramData\updatecheck.ps1 (hash, firma, contenido, fecha de creación) y determinar cómo llegaron al host.<br>• Determinar el origen de la sesión de CORP\helpdesk desde 10.10.3.18: tipo de inicio de sesión, eventos de autenticación previos y si la actividad fue autorizada por el equipo de TI.<br>• Revisar el proceso padre y la actividad de red (DNS, proxy, firewall) de wuhelper.exe en APP-SRV01 durante 11:37–12:04 y después; no hay evidencia en los logs sobre esto en el grupo.<br>• Verificar si la tarea y el servicio siguen activos y si updatecheck.ps1 se ejecutó; buscar la misma tarea, servicio o rutas en otros hosts.<br>• Revisar otra actividad de CORP\helpdesk y de 10.10.3.18 en el resto del dataset, y si la cuenta tiene permisos para crear tareas y servicios. | • Aislar APP-SRV01 de la red, o restringir su conectividad, mientras se valida la legitimidad de la actividad.<br>• Deshabilitar o restablecer la credencial de CORP\helpdesk y cerrar sus sesiones activas.<br>• Detener y deshabilitar el servicio WinUpdateHelper y la tarea \Microsoft\Windows\UpdateCheck tras preservar evidencia forense (copias de los archivos y memoria si es posible). | • Eliminar la tarea programada, el servicio y los archivos de ProgramData una vez completado el análisis forense; reconstruir el host si se confirma compromiso.<br>• Rotar las credenciales de CORP\helpdesk y de cuentas que hayan iniciado sesión en APP-SRV01; aplicar mínimo privilegio para evitar que cuentas de soporte creen servicios y tareas en servidores.<br>• Crear alertas para los Event_ID 4698 y 7045 con rutas en ProgramData o directorios de usuario y para nombres que imiten componentes de Windows; considerar application control (AppLocker/WDAC) para ProgramData. |

CRÍTICO

## INC-006 Ataque web contra WEB-01 desde 192.0.2.91 con posible ejecución remota de comandos (cmd.exe lanzado por DefaultAppPool)

2026-10-23 12:10:00 a 12:15:00 · Hosts: WEB-01 · IP externas: 192.0.2.91 · Cuentas: DefaultAppPool

Entre las 12:10:00 y las 12:14:00 la IP externa 192.0.2.91 envió 21 peticiones HTTP a WEB-01:443 (IIS), una cada 12 s, lo que es consistente con automatización. Las URI fueron /login?user=admin (8), /admin/ (5), /api/v1/export (5) y /uploads/test.aspx?cmd=whoami (3). La primera petición de webshell (EVT-00571, 12:10:00) devolvió HTTP 200 y las dos siguientes (EVT-00573, EVT-00574) devolvieron 404. El conjunto de respuestas fue 6 HTTP 200, 6 HTTP 404 y 9 HTTP 500. A las 12:15:00, un minuto después de la última petición, el evento 4688 EVT-00599 registró que la identidad del servicio web IIS APPPOOL\DefaultAppPool ejecutó "cmd.exe /c whoami" en WEB-01, con Source_IP 192.0.2.91. El patrón sugiere una webshell o una ejecución remota de comandos (T1190, T1505.003). Los logs no prueban que el archivo test.aspx se haya subido ni que la petición provocara el proceso. Tampoco hay evidencia en los logs de proceso padre, de acciones posteriores ni de exfiltración.

**Confianza de la agrupación:** Media. Las peticiones web con patrón de webshell, el origen externo único y la ejecución de cmd.exe /c whoami por la identidad del servicio web están documentados. Sin embargo, el vínculo causal es solo temporal: no hay evidencia en los logs del proceso padre, de la creación o subida de test.aspx, ni de actividad posterior. Además, la petición de webshell con HTTP 200 es seguida por dos 404, y el comando aparece 60 s después de la última petición. Los intentos contra /login no muestran resultado de autenticación.

### CRONOLOGÍA

| Hora | Paso | Evidencia |
|---|---|---|
| 12:10:00 | Primera petición con patrón de webshell (/uploads/test.aspx?cmd=whoami) desde 192.0.2.91; respuesta HTTP 200. | EVT-00571 |
| 12:10:12 | Petición a /login?user=admin (HTTP 200). El patrón se repite durante toda la ventana, con 8 peticiones en total y respuestas 200, 404 y 500. | EVT-00572, EVT-00586, EVT-00589, EVT-00591 … (+3) |
| 12:10:24 | Dos nuevas peticiones a /uploads/test.aspx?cmd=whoami, ambas con HTTP 404 (12:10:24 y 12:10:36). | EVT-00573, EVT-00574 |
| 12:10:48 | Enumeración de /admin/ (HTTP 500 en la primera petición). Continúa con otras 4 peticiones hasta las 12:12:12. | EVT-00576, EVT-00581, EVT-00583, EVT-00584 … (+1) |
| 12:11:00 | Peticiones a /api/v1/export (HTTP 200 a las 12:11:00; después 404 y 500; HTTP 200 de nuevo a las 12:14:00). | EVT-00577, EVT-00582, EVT-00588, EVT-00590 … (+1) |
| 12:15:00 | El proceso de IIS APPPOOL\DefaultAppPool ejecutó 'cmd.exe /c whoami' en WEB-01 (evento 4688), con Source_IP 192.0.2.91. | EVT-00599 |

CRÍTICO **F-020 Ataque web contra WEB-01 desde 192.0.2.91**

Otras anomalías · Acceso inicial · MITRE ATT&CK (orientativo): T1190, T1505.003 · 12:10:00–12:14:00 · 21 eventos

### CRITICIDAD Y JUSTIFICACIÓN

El motor lo clasificó como Crítico por los hechos siguientes: cadencia automatizada (21 peticiones en 240 s), 3 peticiones con patrón de webshell/inyección (la primera con HTTP 200, EVT-00571), abundantes respuestas 4xx/5xx que indican sondeo de recursos y, poco después, la ejecución de un proceso hijo por el servicio web (EVT-00599). La combinación de patrón de webshell, respuesta exitosa y un posterior comando en el servidor justifica la máxima prioridad.

### EXPLICACIÓN TÉCNICA

Desde 192.0.2.91 se registraron 21 peticiones HTTP a WEB-01:443 (IIS) entre 12:10:00 y 12:14:00, con mediana de 12 s entre peticiones, lo que es consistente con una herramienta automatizada. Tres peticiones (EVT-00571, EVT-00573, EVT-00574) apuntan a /uploads/test.aspx?cmd=whoami, un patrón típico de uso de webshell (T1505.003). La primera (EVT-00571) devolvió HTTP 200 y las otras dos HTTP 404. Un HTTP 200 no prueba por sí solo que el comando se ejecutara. Además se repitieron /login?user=admin (8 peticiones, con respuestas 200, 404 y 500), /admin/ (5) y /api/v1/export (5). Esto sugiere reconocimiento y posible intento de acceso (T1190). Las respuestas fueron 6 HTTP 200, 6 HTTP 404 y 9 HTTP 500. Los logs no indican si los intentos contra /login lograron autenticar a alguien. Tampoco prueban qué datos se devolvieron en /api/v1/export (HTTP 200 en EVT-00577 y EVT-00596).

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00571** | 12:10:00 | WEB-01 | - | 192.0.2.91 | HTTP_ACCESS · /uploads/test.aspx?cmd=whoami | Warning |
| **EVT-00572** | 12:10:12 | WEB-01 | - | 192.0.2.91 | HTTP_ACCESS · /login?user=admin | Warning |
| **EVT-00573** | 12:10:24 | WEB-01 | - | 192.0.2.91 | HTTP_ACCESS · /uploads/test.aspx?cmd=whoami | Warning |
| **EVT-00574** | 12:10:36 | WEB-01 | - | 192.0.2.91 | HTTP_ACCESS · /uploads/test.aspx?cmd=whoami | Warning |
| **EVT-00576** | 12:10:48 | WEB-01 | - | 192.0.2.91 | HTTP_ACCESS · /admin/ | Warning |
| **EVT-00577** | 12:11:00 | WEB-01 | - | 192.0.2.91 | HTTP_ACCESS · /api/v1/export | Warning |
| **EVT-00579** | 12:11:12 | WEB-01 | - | 192.0.2.91 | HTTP_ACCESS · /login?user=admin | Warning |
| **EVT-00581** | 12:11:24 | WEB-01 | - | 192.0.2.91 | HTTP_ACCESS · /admin/ | Warning |
| **EVT-00582** | 12:11:36 | WEB-01 | - | 192.0.2.91 | HTTP_ACCESS · /api/v1/export | Warning |
| **EVT-00595** | 12:13:48 | WEB-01 | - | 192.0.2.91 | HTTP_ACCESS · /login?user=admin | Warning |
| **EVT-00596** | 12:14:00 | WEB-01 | - | 192.0.2.91 | HTTP_ACCESS · /api/v1/export | Warning |

Se muestran 11 de 21 eventos (primeros 9 y últimos 2). Rango completo: EVT-00571 a EVT-00596. IDs completos: EVT-00571, EVT-00572, EVT-00573, EVT-00574, EVT-00576, EVT-00577, EVT-00579, EVT-00581, EVT-00582, EVT-00583, EVT-00584, EVT-00585, EVT-00586, EVT-00588, EVT-00589, EVT-00590, EVT-00591, EVT-00592, EVT-00593, EVT-00595, EVT-00596

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Si la webshell existe y funciona, un atacante externo podría ejecutar comandos en WEB-01 con la identidad del pool de aplicaciones. Eso pondría en riesgo la confidencialidad e integridad del servidor y de los datos que expone, y podría servir de punto de apoyo para moverse hacia otros sistemas. Los logs no permiten confirmar el alcance. Hay evidencia de peticiones a /api/v1/export con HTTP 200, pero no hay evidencia en los logs de qué datos se devolvieron.

### PLAN DE ACCIÓN

| Investigar | Contener | Remediar |
|---|---|---|
| • Revisar si existe /uploads/test.aspx en WEB-01 y, si existe, cuándo se creó, su hash y su contenido. Revisar también otros archivos .aspx recientes en /uploads/. Los logs entregados no muestran su creación.<br>• Consultar los logs de IIS completos (incluidos tamaños de respuesta y user-agent, si están disponibles) para las 21 peticiones. Conviene ampliar la búsqueda a actividad anterior y posterior de 192.0.2.91 en toda la infraestructura.<br>• Determinar cómo llegó el archivo test.aspx a /uploads/ (vulnerabilidad de subida, credenciales comprometidas u otro vector). No hay evidencia en los logs sobre este punto.<br>• Revisar qué devolvió /api/v1/export con HTTP 200 (EVT-00577, EVT-00596) y si hubo acceso a datos sensibles.<br>• Revisar los intentos contra /login?user=admin y los errores HTTP 500 (EVT-00586, EVT-00589, EVT-00593, EVT-00595) para detectar posibles autenticaciones exitosas o fallos explotables en la aplicación. | • Bloquear 192.0.2.91 en el WAF o firewall perimetral hacia WEB-01.<br>• Restringir temporalmente la ejecución de scripts en /uploads/ y valorar aislar WEB-01 de la red hasta completar la revisión forense.<br>• Preservar los logs de IIS y una imagen del servidor antes de modificar su estado. | • Eliminar la webshell, si se confirma, y corregir el vector de subida o ejecución que permitió su presencia.<br>• Deshabilitar la ejecución de scripts en directorios de subida, aplicar listas de extensiones permitidas y reglas WAF para detectar parámetros como cmd=.<br>• Restringir o proteger con autenticación fuerte /admin/ y /api/v1/export, y añadir limitación de tasa en /login.<br>• Rotar credenciales y secretos que la aplicación pueda haber expuesto si se confirma el compromiso. |

## CRÍTICO F-021 Shell iniciada por el servicio web en WEB-01 (DefaultAppPool)

Comandos y procesos · Ejecución · MITRE ATT&CK (orientativo): T1505.003, T1190 · 12:15:00–12:15:00 · 1 evento

### CRITICIDAD Y JUSTIFICACIÓN

El motor lo clasificó como Crítico porque coincide con el patrón «Shell iniciada por el servicio web», la actividad se asocia a la IP externa 192.0.2.91 y la cuenta ejecutora es la identidad del servicio web (IIS APPPOOL\DefaultAppPool). Es la señal más cercana a la confirmación de ejecución de comandos en el servidor.

### EXPLICACIÓN TÉCNICA

El evento 4688 EVT-00599 (12:15:00) registra que la cuenta IIS APPPOOL\DefaultAppPool, identidad del servicio web, creó en WEB-01 un proceso con la línea de comandos "cmd.exe /c whoami". El evento incluye Source_IP 192.0.2.91, la misma IP que realizó las peticiones del hallazgo F-020. Un servicio web que lanza cmd.exe es un indicador clásico de webshell o ejecución remota de comandos (T1505.003, T1190). Es coherente con el parámetro cmd=whoami de EVT-00571, EVT-00573 y EVT-00574, y ocurrió 60 s después de la última petición registrada (EVT-00596). La correlación es temporal y de comando: no hay evidencia en los logs del proceso padre ni de la salida de whoami. Tampoco hay evidencia en los logs de comandos posteriores.

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00599** | 12:15:00 | WEB-01 | DefaultApp Pool | 192.0.2.91 | 4688 · cmd.exe /c whoami | Warning |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Indica que un proceso controlado por el servicio web pudo ejecutar comandos del sistema en WEB-01. Si se confirma, el atacante puede explorar el entorno con los privilegios de DefaultAppPool y preparar acciones posteriores. En los logs entregados, el único comando registrado es whoami, que es de reconocimiento. No hay evidencia en los logs de acciones posteriores.

## PLAN DE ACCIÓN

| Investigar | Contener | Remediar |
|---|---|---|
| • Obtener el proceso padre de EVT-00599 (por ejemplo w3wp.exe) y su línea de comandos, y confirmar que cmd.exe fue lanzado desde el worker de IIS. Esta información no está en los logs entregados.<br>• Buscar en WEB-01 otros eventos 4688 o telemetría EDR de la cuenta IIS APPPOOL\DefaultAppPool (PowerShell, creación de usuarios, descargas, conexiones salientes) después de las 12:15:00.<br>• Revisar conexiones de red salientes desde WEB-01 y el uso de la cuenta de servicio en otros hosts tras el evento.<br>• Correlacionar EVT-00599 con las peticiones de EVT-00571, EVT-00573 y EVT-00574 usando logs de IIS con mayor detalle. | • Aislar WEB-01 de la red, o restringir su tráfico saliente, mientras se verifica el compromiso.<br>• Detener o reciclar el pool DefaultAppPool tras preservar la evidencia volátil (memoria, procesos activos).<br>• Vigilar o bloquear el uso de la cuenta IIS APPPOOL\DefaultAppPool fuera de WEB-01. | • Aplicar el principio de mínimo privilegio al pool de aplicaciones y bloquear que w3wp.exe lance cmd.exe o powershell mediante AppLocker, WDAC o reglas de EDR.<br>• Crear una alerta permanente para procesos cmd.exe o powershell.exe hijos del servicio web.<br>• Si se confirma el compromiso, reconstruir WEB-01 desde una imagen limpia y revisar la integridad del código de la aplicación. |

# 5. Observaciones generales (SIEM y calidad de datos)

Hallazgos que no forman parte de una cadena de ataque concreta pero afectan la capacidad de detección o la fiabilidad de los datos.

MEDIO **F-022 El SIEM clasificó como 'Informational' 10 eventos que forman parte de incidentes**

Otras anomalías · Calidad de datos / SIEM · 08:39:00–12:04:00 · 10 eventos

### CRITICIDAD Y JUSTIFICACIÓN

Severidad Medio fijada por el motor: 10 de 122 eventos de evidencia (8 %) están como Informational. Es un fallo de detección que puede retrasar la atención de actividad relevante, pero no es en sí una actividad maliciosa.

### EXPLICACIÓN TÉCNICA

De 122 eventos que sustentan otros hallazgos, 10 tienen Severity=Informational. Son: inicio de sesión exitoso de CORP\mgarcia desde 203.0.113.74 en DC-01 (EVT-00123); asignación de privilegios especiales a la misma cuenta y origen en WS-031 (EVT-00126); acceso de CORP\backupsvc a \\FS-SRV01\Finance (EVT-00315); acceso de CORP\rrojas a \\FS-SRV01\Legal (EVT-00419); ejecución del comando '7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx' en WS-018 (EVT-00428), que es un comando para comprimir archivos y no prueba que se creara el archivo; y cinco ejecuciones de C:\ProgramData\wuhelper.exe por CORP\helpdesk en APP-SRV01 (EVT-00528, EVT-00542, EVT-00548, EVT-00559, EVT-00564). Esto sugiere que las reglas de severidad del SIEM no habrían priorizado estos comportamientos.

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00123** | 08:39:00 | DC-01 | mgarcia | 203.0.113.74 | 4624 · An account was successfully logged on | Informational |
| **EVT-00126** | 08:40:00 | WS-031 | mgarcia | 203.0.113.74 | 4672 · Special privileges assigned to new logon | Informational |
| **EVT-00315** | 09:43:00 | FS-SRV01 | backupsvc | 10.10.1.44 | 5145 · A network share object was checked to see whether client can be granted desired access | Informational |
| **EVT-00419** | 10:40:00 | FS-SRV01 | rrojas | 10.10.1.31 | 5140 · A network share object was accessed | Informational |
| **EVT-00428** | 10:42:00 | WS-018 | rrojas | 10.10.1.31 | 4688 · 7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx | Informational |
| **EVT-00528** | 11:40:00 | APP-SRV01 | helpdesk | 10.10.3.18 | 4688 · C:\ProgramData\wuhelper.exe | Informational |
| **EVT-00542** | 11:46:00 | APP-SRV01 | helpdesk | 10.10.3.18 | 4688 · C:\ProgramData\wuhelper.exe | Informational |
| **EVT-00548** | 11:52:00 | APP-SRV01 | helpdesk | 10.10.3.18 | 4688 · C:\ProgramData\wuhelper.exe | Informational |
| **EVT-00559** | 11:58:00 | APP-SRV01 | helpdesk | 10.10.3.18 | 4688 · C:\ProgramData\wuhelper.exe | Informational |
| **EVT-00564** | 12:04:00 | APP-SRV01 | helpdesk | 10.10.3.18 | 4688 · C:\ProgramData\wuhelper.exe | Informational |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Posible falta de alertas prioritarias ante comportamientos que forman parte de otros incidentes. Esto puede aumentar el tiempo de detección y respuesta.

### PLAN DE ACCIÓN

**Investigar**

- Revisar qué reglas y mapeos de severidad del SIEM clasificaron como Informational los eventos EVT-00123, EVT-00126, EVT-00315, EVT-00419, EVT-00428, EVT-00528, EVT-00542, EVT-00548, EVT-00559 y EVT-00564.
- Comprobar si existen alertas previas o posteriores para esa misma actividad en otras fuentes. No hay evidencia en los logs.

**Contener**

- No se requiere contención por este hallazgo. Las acciones de contención corresponden a los incidentes asociados.

**Remediar**

- Ajustar las reglas de correlación y de severidad del SIEM para elevar: logons externos de cuentas internas, asignación de privilegios especiales desde IP externa, compresión de datos con herramientas de archivado, ejecuciones repetidas de binarios en C:\ProgramData y accesos masivos a recursos compartidos sensibles.
- Validar el cambio con pruebas de detección tras el ajuste.

## BAJO F-023 Nombres de host inconsistentes: DC-01 / DC01

Otras anomalías · Calidad de datos / SIEM · 07:48:11–08:50:12 · 6 eventos

### CRITICIDAD Y JUSTIFICACIÓN

Severidad Bajo fijada por el motor: se trata de una inconsistencia de nomenclatura (2 variantes, 91 y 30 eventos) sin indicios de actividad maliciosa en los logs.

### EXPLICACIÓN TÉCNICA

El mismo equipo aparece con dos grafías: DC-01 (91 eventos) y DC01 (30 eventos). Ejemplos: DC-01 en EVT-00005, EVT-00014 y EVT-00019; DC01 en EVT-00125, EVT-00136 y EVT-00149. El motor no lo interpretó como actividad maliciosa. Se trata de un problema de normalización que puede fragmentar las correlaciones por host.

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00005** | 07:48:11 | DC-01 | slopez | 10.10.2.24 | 4625 · An account failed to log on | Informational |
| **EVT-00014** | 07:55:07 | DC-01 | rrojas | 10.10.2.24 | 5140 · A network share object was accessed | Informational |
| **EVT-00019** | 07:59:09 | DC-01 | backupsvc | 10.10.1.31 | 4624 · An account was successfully logged on | Informational |
| **EVT-00125** | 08:39:48 | DC01 | svc_backup | 10.10.2.15 | 4624 · An account was successfully logged on | Informational |
| **EVT-00136** | 08:45:15 | DC01 | mruiz | 10.10.1.14 | 4624 · An account was successfully logged on | Informational |
| **EVT-00149** | 08:50:12 | DC01 | jlopez | 10.10.1.14 | 4634 · An account was logged off | Informational |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Las correlaciones y búsquedas por host pueden quedar incompletas y ocultar actividad en el controlador de dominio.

### PLAN DE ACCIÓN

| Investigar | Contener | Remediar |
|---|---|---|
| • Confirmar en el origen que DC-01 y DC01 corresponden al mismo equipo y qué colector o parser genera cada variante. | • No se requiere contención. | • Normalizar el campo Hostname en el SIEM (alias o enriquecimiento) y revisar las consultas y reglas por host para incluir ambas variantes. |

## BAJO F-024 Cuentas con nombres casi idénticos: backupsvc / svc_backup

Otras anomalías · Calidad de datos / SIEM · 07:59:09–08:40:37 · 4 eventos

### CRITICIDAD Y JUSTIFICACIÓN

Severidad Bajo fijada por el motor: hay dos cuentas de nombre casi idéntico (76 y 24 eventos), pero la evidencia no demuestra uso indebido atribuible a esta similitud.

### EXPLICACIÓN TÉCNICA

Existen las cuentas CORP\backupsvc (76 eventos) y CORP\svc_backup (24 eventos), con las mismas componentes en distinto orden. Ejemplos de backupsvc: EVT-00019 y EVT-00030. Ejemplos de svc_backup: EVT-00125 (logon exitoso) y EVT-00129 (logon fallido en WS-014). Puede ser una convención legítima o una cuenta creada para confundir (T1036, según el motor). Los logs no permiten decidirlo.

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00019** | 07:59:09 | DC-01 | backupsvc | 10.10.1.31 | 4624 · An account was successfully logged on | Informational |
| **EVT-00030** | 08:10:58 | WS-031 | backupsvc | 10.10.2.15 | 5140 · A network share object was accessed | Informational |
| **EVT-00125** | 08:39:48 | DC01 | svc_backup | 10.10.2.15 | 4624 · An account was successfully logged on | Informational |
| **EVT-00129** | 08:40:37 | WS-014 | svc_backup | 10.10.2.24 | 4625 · An account failed to log on | Informational |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Si una de las cuentas no fuera legítima, podría dificultar la detección y atribución de actividad de respaldo o servicio. Por ahora es solo una posibilidad: no hay evidencia en los logs.

### PLAN DE ACCIÓN

| Investigar | Contener | Remediar |
|---|---|---|
| • Validar en Active Directory quién creó cada cuenta, cuándo, para qué sirve y a qué grupos pertenece.<br>• Comparar los orígenes y destinos de uso de ambas cuentas (EVT-00019, EVT-00030, EVT-00125, EVT-00129) con los sistemas de respaldo documentados. | • No se requiere contención con la evidencia actual. Si la validación en AD revela que una cuenta no es legítima, deshabilitarla y restablecer credenciales. | • Documentar y estandarizar la convención de nombres de cuentas de servicio.<br>• Retirar la cuenta redundante si no tiene uso justificado. |

## BAJO F-025 Evento 7036 registrado con fuente distinta de 'System'

Otras anomalías · Calidad de datos / SIEM · 13:14:26–13:14:26 · 1 evento

### CRITICIDAD Y JUSTIFICACIÓN

Severidad Bajo fijada por el motor: se trata de un único evento con un campo de fuente inconsistente y no hay evidencia de impacto operativo.

### EXPLICACIÓN TÉCNICA

EVT-00675 (13:14:26, DC-01, Event ID 7036, 'Service entered running state', usuario CORP\rrojas) figura con Log_Source='Security'. El Event ID 7036 pertenece al registro System. Puede ser un error de parseo o una inserción de eventos; los logs no permiten decidir cuál.

### EVIDENCIAS EN LOS LOGS

| Log_ID | Hora | Host | Usuario | IP origen | Evento / comando | SIEM |
|---|---|---|---|---|---|---|
| **EVT-00675** | 13:14:26 | DC-01 | rrojas | 10.10.2.24 | 7036 · Service entered running state | Informational |

### POSIBLE IMPACTO EN LA ORGANIZACIÓN

Puede indicar un error de parseo o un problema de integridad del dato, lo que reduce la confianza en la fuente de logs.

### PLAN DE ACCIÓN

| Investigar | Contener | Remediar |
|---|---|---|
| • Verificar EVT-00675 en el origen (DC-01) y determinar si existe en el registro System.<br>• Revisar si el parser asigna Log_Source de forma incorrecta a otros eventos 7036. | • No se requiere contención. | • Corregir el mapeo de Log_Source del Event ID 7036 en el colector o parser del SIEM. |

# 6. Indicadores de compromiso (IoC)

Indicadores extraídos de las evidencias. El export no contiene hashes de archivos ni reputación de IP; esos datos deben obtenerse en el endpoint o con inteligencia de amenazas.

| Tipo | Valor | Crit. | Primera vez | Contexto | Hallazgos |
|---|---|---|---|---|---|
| IP | **192.0.2.91** | Crítico | 12:10:00 | Origen del ataque web; Origen externo de la actividad (22 eventos en el export) | F-020, F-021 |
| IP | **198.51.100.77** | Crítico | 09:02:00 | Origen de la ráfaga de autenticaciones fallidas; IP externa con sesión exitosa (11 eventos en el export) | F-004, F-005, F-007, F-008 |
| IP | **198.51.100.88** | Crítico | 10:43:00 | Destino de la transferencia saliente (22 eventos en el export) | F-018 |
| IP | **203.0.113.88** | Crítico | 09:21:00 | Destino externo de conexión iniciada por shell (1 evento en el export) | F-012 |
| IP | **203.0.113.74** | Alto | 08:25:00 | Origen de la ráfaga de autenticaciones fallidas; IP externa con sesión exitosa (35 eventos en el export) | F-001, F-002 |
| Cuenta | **CORP\admin** | Crítico | 09:06:00 | Cuenta usada desde IP externa; Cuenta involucrada en actividad sospechosa (16 eventos en el export) | F-005, F-006, F-007, F-008 |
| Cuenta | **CORP\backupsvc** | Crítico | 09:36:00 | Cuenta involucrada en actividad sospechosa (76 eventos en el export) | F-013, F-014, F-015 |
| Cuenta | **CORP\rrojas** | Crítico | 10:40:00 | Cuenta involucrada en actividad sospechosa (72 eventos en el export) | F-016, F-017, F-018 |
| Cuenta | **IIS APPPOOL\DefaultAppPool** | Crítico | 12:15:00 | Cuenta involucrada en actividad sospechosa (1 evento en el export) | F-021 |
| Cuenta | **CORP\helpdesk** | Alto | 11:37:00 | Cuenta involucrada en actividad sospechosa (94 eventos en el export) | F-019 |
| Cuenta | **CORP\mgarcia** | Alto | 08:39:00 | Cuenta usada desde IP externa; Cuenta involucrada en actividad sospechosa (66 eventos en el export) | F-002, F-003 |
| Host | **FS-SRV01** | Crítico | 09:15:00 | Destino de movimiento lateral desde APP-SRV01 (91 eventos en el export) | F-009 |
| Servicio/Tarea | **WinUpdateHelper** | Alto | 11:37:00 | Nombre usado para persistencia | F-019 |
| Servicio/Tarea | **\Microsoft\Windows\UpdateCheck** | Alto | 11:37:00 | Nombre usado para persistencia | F-019 |
| Ruta/archivo | **C:\Temp\finance.zip** | Crítico | 09:20:00 | Compresión de datos (staging) | F-011 |
| Ruta/archivo | **C:\Temp\reports** | Crítico | 09:20:00 | Compresión de datos (staging) | F-011 |
| Ruta/archivo | **C:\Legal*.docx** | Alto | 10:42:00 | Compresión de datos (staging) | F-017 |
| Ruta/archivo | **C:\ProgramData\updatecheck.ps1** | Alto | 11:37:00 | Binario/script de persistencia | F-019 |
| Ruta/archivo | **C:\ProgramData\wuhelper.exe** | Alto | 11:37:00 | Binario/script de persistencia | F-019 |
| Ruta/archivo | **C:\Users\Public\archive.7z** | Alto | 10:42:00 | Compresión de datos (staging) | F-017 |
| Ruta/archivo | **Finance\FY2026\document_000.xlsx** | Alto | 09:37:00 | Primer archivo del barrido | F-014 |
| Ruta/archivo | **Finance\FY2026\document_015.xlsx** | Alto | 09:37:00 | Último archivo del barrido | F-014 |
| Ruta/archivo | **\\FS-SRV01\Finance** | Alto | 09:17:00 | Recurso sensible accedido | F-010 |
| Ruta/archivo | **\\FS-SRV01\Legal** | Medio | 10:40:00 | Recurso sensible accedido | F-016 |
| URL/URI | **/admin/** | Crítico | 12:10:00 | Solicitada 5 veces | F-020 |
| URL/URI | **/api/v1/export** | Crítico | 12:10:00 | Solicitada 5 veces | F-020 |
| URL/URI | **/login?user=admin** | Crítico | 12:10:00 | Solicitada 8 veces | F-020 |
| URL/URI | **/uploads/test.aspx?cmd=whoami** | Crítico | 12:10:00 | Solicitada 3 veces | F-020 |
| URL/URI | **https://198.51.100.88/upload/session/N** | Crítico | 10:43:00 | Patrón de subida | F-018 |
| Comando | **cmd.exe /c whoami** | Crítico | 12:15:00 | Shell iniciada por el servicio web | F-021 |
| Comando | **powershell.exe -NoProfile -EncodedCommand [REDACTED_SYNTHETIC]** | Crítico | 09:09:00 | PowerShell con comando codificado | F-007 |

| Tipo | Valor | Crit. | Primera vez | Contexto | Hallazgos |
|---|---|---|---|---|---|
| Comando | **tar.exe -a -c -f C:\Temp\finance.zip C:\Temp\reports** | Crítico | 09:20:00 | Compresión de datos (staging) | F-011 |
| Comando | **vssadmin.exe delete shadows /all /quiet** | Crítico | 09:42:00 | Eliminación de copias de sombra (anti-recuperación) | F-015 |
| Comando | **7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx** | Alto | 10:42:00 | Compresión de datos (staging) | F-017 |
| Comando | **PowerShell Script Block: Get-LocalGroupMember Administrators; Get-SmbShare** | Alto | 09:11:00 | Comandos de reconocimiento | F-008 |
| Comando | **net.exe view \\FS-SRV01** | Alto | 09:11:00 | Comandos de reconocimiento | F-008 |
| Comando | **powershell.exe -NoProfile -EncodedCommand <base64_redacted>** | Alto | 09:36:00 | PowerShell con comando codificado | F-013 |

# 7. Plan de acción priorizado

| Prioridad | Acción | Incidentes |
|---|---|---|
| **Inmediata** | Contener APP-SRV01 y FS-SRV01. Aislar APP-SRV01 de la red, restablecer la contraseña de CORP\admin, cerrar sus sesiones activas y bloquear el RDP externo desde 198.51.100.77. Revisar con el firewall y el proxy si hubo tráfico real hacia 203.0.113.88:443 y bloquear ese destino (EVT-00188, EVT-00198, EVT-00232, EVT-00235). | INC-002 |
| **Inmediata** | Aislar WS-018 y bloquear 198.51.100.88. Con el proxy, confirmar el volumen y el contenido de los 22 POST (~253,3 MB) y preservar C:\Users\Public\archive.7z. Restablecer las credenciales de CORP\rrojas (EVT-00428, EVT-00430 a EVT-00461). | INC-004 |
| **Inmediata** | Aislar WEB-01 y bloquear 192.0.2.91. Verificar si existe /uploads/test.aspx y cuándo se creó. Revisar el proceso padre de cmd.exe y la actividad posterior de DefaultAppPool, y preservar los logs de IIS (EVT-00571, EVT-00573, EVT-00574, EVT-00599). | INC-006 |
| **Inmediata** | Aislar WS-023 y restablecer las credenciales de CORP\backupsvc. Comprobar si las copias de sombra se eliminaron realmente y si existen copias fuera de línea. Revisar si hay cifrado o actividad anómala en FS-SRV01\Finance y decodificar el script PowerShell para conocer su contenido (EVT-00280, EVT-00284 a EVT-00309, EVT-00314). | INC-003 |
| **Inmediata** | Bloquear 203.0.113.74 y restablecer la contraseña de CORP\mgarcia con cierre de sesiones. Revisar la sesión en DC-01 y la asignación de privilegios en WS-031 (EVT-00123, EVT-00126). Comprobar también si las demás cuentas atacadas (jlopez, aperez, helpdesk, rrojas, slopez, backupsvc, dtorres) registran inicios de sesión exitosos. | INC-001 |
| **Corto plazo** | Eliminar la persistencia en APP-SRV01: la tarea \Microsoft\Windows\UpdateCheck y el servicio WinUpdateHelper. Analizar updatecheck.ps1 y wuhelper.exe, y revisar el origen y el uso de la cuenta CORP\helpdesk (EVT-00523, EVT-00524, EVT-00528, EVT-00542, EVT-00548, EVT-00559, EVT-00564). | INC-005 |
| **Corto plazo** | Evaluar el impacto sobre la confidencialidad de los datos de Finance (incluido Finance\Budget2027.xlsx) y de Legal. Valorar las obligaciones de notificación según lo que confirme la investigación (EVT-00227, EVT-00231, EVT-00419). | INC-002, INC-003, INC-004 |
| **Mediano plazo** | Revisar la exposición de RDP y de aplicaciones web a Internet. Aplicar bloqueo por intentos fallidos y MFA para accesos remotos y cuentas privilegiadas. | INC-001, INC-002, INC-006 |

# 8. Recomendaciones generales de seguridad

- Habilitar MFA para todo acceso remoto y bloqueo inteligente de cuentas; alertar ráfagas de 4625 por IP de origen.
- Eliminar la exposición directa de RDP/servicios administrativos a Internet (VPN o ZTNA con MFA) y revisar las reglas de firewall de entrada.
- Aplicar mínimo privilegio, separar cuentas administrativas de las de uso diario y gestionar accesos privilegiados (PAM).
- Activar PowerShell Script Block Logging, AMSI y Constrained Language Mode; aplicar AppLocker/WDAC para limitar la ejecución.
- Segmentar la red entre servidores, restringir SMB/administración remota y usar contraseñas de administrador únicas por host (LAPS).
- Mantener backups offline e inmutables, probar la restauración y alertar de inmediato cualquier uso de vssadmin/wbadmin delete.
- Implementar DLP y filtrado de salida (egress) con alertas por volumen de subida y destinos nuevos.
- Monitorear 4698/7045, restringir la creación de servicios/tareas y bloquear la ejecución desde ProgramData/Temp.

- Proteger las aplicaciones expuestas con WAF, impedir ejecución en directorios de subida y ejecutar los pools con mínimo privilegio.
- Revisar la severidad y las reglas de correlación del SIEM: varios eventos que sustentan incidentes quedaron como Informational.
- Normalizar nombres de host y fuentes de log en el pipeline del SIEM para no fragmentar correlaciones.
- Conservar y centralizar los logs (retención suficiente) y garantizar cobertura EDR en servidores críticos.
- Documentar un procedimiento de respuesta a incidentes y ejercitarlo con los equipos de TI y Legal.